CASE STUDY

The Year 2024 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

For the people who defend networks, 2024 was a year of two doors and one long shadow. The first door was the appliance at the edge: the year opened with Ivanti Connect Secure gateways exploited as zero-days, an emergency directive that told federal agencies to apply Ivanti's updates within 48 hours of release, and a joint advisory that found the vendor's own integrity checker had missed compromise; Palo Alto Networks, Cisco, Fortinet, ConnectWise, Check Point and Cleo products followed. The second door was a password with no second factor behind it: a legacy test account at Microsoft, customer accounts at a cloud data platform, and VPN logins for ransomware affiliates. The long shadow was the state actor that waits: US and allied agencies said a PRC state-sponsored group had held footholds in some US critical infrastructure networks for at least five years, and by November the FBI and CISA were describing a broad espionage campaign inside multiple telecommunications companies. Against that, law enforcement struck ransomware hard. Operation Cronos took control of LockBit's administration environment, its leader was named and sanctioned, coordinated operations hit droppers and infostealers, and Treasury sanctioned the operators of a residential proxy botnet. The outage that crashed an estimated 8.5 million Windows devices on 19 July was no attack at all, but a faulty security update. Governments answered with emergency directives, sanctions on Chinese, Russian, Iranian and criminal actors, a ban on one antivirus vendor's sales, CSF 2.0, the first post-quantum standards, a UN cybercrime convention and the NIS2 deadline.

This study is the dated record of that year. It is a chronicle, not a deep dive: where another study in this series is the home for an event, this one gives a paragraph and a link. Change Healthcare is told in the Change Healthcare study; the XZ Utils backdoor in the XZ Utils study; FrostyGoop, Fuxnet and the year's other industrial events in the ICS attacks and advisories study; the longer records of the state actors in the China-attributed, Russia-attributed, Iran-attributed and North Korea-attributed actor studies and in the Sandworm study; and the commercial spyware market in the zero-day market study. The OpenSSH regreSSHion flaw belongs to the SSHole OpenSSH study, which places it in the lineage of OpenSSH flaws.

Everything else in 2024 that the verified record supports is here, in date order, with the source behind each line.

> Evidence grade: the events, attributions, sanctions, rules and laws are **Confirmed** from the government agency, the victim's own statement or SEC filing, the vendor that observed the activity, the CVE, NVD and KEV records, or the MITRE record. Annual estimates from vendor datasets (Chainalysis payments, Coveware's payment rate, Lumen's botnet counts) and statements a vendor relays from others are **Reported** and attributed by name. Checks this study re-ran against the library's ATT&CK, CWE, CAPEC and D3FEND data are **Demonstrated**. Where this study draws its own conclusion or maps behavior to ATT&CK on its own reading, it says **Inferred**.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2024, with lead-in events from May 2023 and later records that describe 2024
The edge-device year	Zero-days or near zero-days in Ivanti Connect Secure (Dec 2023 to Jan), Cisco ASA (ArcaneDoor, to Apr), PAN-OS GlobalProtect (from 26 Mar), FortiManager (from 27 Jun) and PAN-OS management (Nov); ScreenConnect, TeamCity, Check Point, PHP-CGI, ESXi, Veeam and Cleo flaws listed in KEV with known ransomware use [2][32][69][91][111][3]
Two emergency directives	ED 24-01 on Ivanti (19 Jan) and ED 24-02 on Microsoft corporate email exfiltrated by Midnight Blizzard (11 Apr) [4][10]
Credentials without MFA	Microsoft's legacy test tenant account, the Snowflake customer accounts in UNC5537's campaign, and Akira's VPN access [132][42][36]
State pre-positioning	Volt Typhoon footholds of at least five years in some US critical infrastructure IT networks (AA24-038A, 7 Feb); PRC-affiliated compromise of multiple telecommunications companies (FBI and CISA, 13 Nov) [13][75]
Ransomware enforcement	Operation Cronos against LockBit (20 Feb); LockBitSupp named and sanctioned (7 May); Evil Corp designations and four more LockBit-linked arrests (1 Oct); Operation Endgame against droppers (May); Operation Magnus against RedLine and META (28 Oct) [93][18][19][65][96][40][72]
Ransomware money	About US$813.55 million in payments, down 35% from 2023 (Chainalysis, Reported); the share of victims who paid fell to 25% in Q4 (Coveware, Reported); IC3 counted 3,156 ransomware complaints and an adjusted loss of US$12,473,156 that leaves out downtime and remediation [99][100][98]
The 19 July outage	A CrowdStrike Falcon content update at 04:09 UTC on 19 July crashed an estimated 8.5 million Windows devices; not a cyberattack [50][52][51]
KEV in 2024	186 entries added during the year, 44 of them now flagged for known ransomware use; Microsoft 36, Ivanti 11, Google 9 (computed from catalog version 2026.11.10) [3]
Policy landmarks	NIST CSF 2.0 (26 Feb); EO 14117 on bulk sensitive data (28 Feb); CIRCIA proposed rule (4 Apr); UK PSTI in force (29 Apr); NSM-22 (30 Apr); Secure by Design pledge (8 May); Kaspersky determination (24 Jun); FIPS 203, 204 and 205 (13 Aug); NIS2 transposition deadline (17 Oct); Australia's Cyber Security Act (29 Nov); UN Convention against Cybercrime adopted (24 Dec) [126][123][124][128][125][139][121][127][129][130][131]
This study's MITRE binding	68 Enterprise technique rows, 47 group, software and campaign objects with library pages, 16 CWE rows with the library's CAPEC pairings, 3 technique-level CAPEC rows, 20 D3FEND countermeasures, and one Navigator layer (Part 13)

Key findings

- **The edge kept falling, and the edge lied about itself.** Ivanti's internal and external Integrity Checker Tool did not detect compromise in CISA's incident responses, and CISA lab research showed root-level persistence could survive a factory reset (Confirmed [5]). Palo Alto Networks, Cisco ASA and FortiManager appliances were exploited before or as their fixes shipped (Confirmed [32][33][91][69]).

- **A missing second factor opened the year's most cited intrusions.** The Microsoft test account Midnight Blizzard sprayed had no MFA; the Snowflake customer accounts UNC5537 used had no MFA and some credentials had not been rotated for up to four years; Akira affiliates came in through VPNs without MFA (Confirmed [132][42][36]; Inferred for the pattern).
- **Infostealers fed the cloud breaches.** Mandiant says at least 79.7 percent of the accounts UNC5537 used had prior credential exposure, the earliest linked infostealer infection dates to November 2020, and contractor devices used for personal activity were a frequent source (Confirmed [42]).
- **The PRC was inside critical infrastructure for the long term.** AA24-038A assesses with high confidence that Volt Typhoon was pre-positioning on IT networks to move to OT and disrupt Communications, Energy, Transportation and Water functions, including in Guam (Confirmed [13]). The FBI and CISA described stolen call records, compromised communications of a limited number of people in government or politics, and copied information subject to US law enforcement requests under court orders at telecommunications companies (Confirmed [75]).
- **Ransomware was hit hard, and payments fell.** Cronos took LockBit's administration environment and leak site and obtained over 1,000 decryption keys; the NCA says more than 7,000 attacks were built with LockBit's services between June 2022 and February 2024 (Confirmed [93][16][18]). Chainalysis estimates payments fell 35% (Reported [99]).
- **Crime and state blurred.** AA24-241A says Iran-based actors sold network access to ransomware affiliates for a share of the payment; AA24-207A says North Korea's Andariel funded espionage with ransomware against US healthcare (Confirmed [59][55]).
- **The worst outage was self-inflicted.** CrowdStrike's faulty Channel File 291 passed its Content Validator because of a bug; CISA and CrowdStrike both say it was not malicious (Confirmed [138][51][50]).
- **Governments used every lever.** Two emergency directives, sanctions on IRGC officers, APT31-linked nationals, LockBit's leader, Evil Corp, Sichuan Silence and the Intellexa consortium, a Commerce ban on Kaspersky, and new binding rules in the UK and the EU (Confirmed [4][10][12][28][19][65][79][26][121][128][129]).

Top recommendations

1. **Put phishing-resistant MFA on every remote and cloud entry point, test and legacy accounts included.** The three 2024 #StopRansomware advisories on Black Basta, Akira and RansomHub put it second only to patching known exploited vulnerabilities, and the year's three most cited credential intrusions turned on its absence (Confirmed [39][36][60][132][42]; Inferred for the reading).
2. **Patch edge appliances on the KEV clock and assume an exploited appliance is lost.** AA24-060B asks for patching within 24 to 48 hours, outbound limits on SSL VPN appliances and reset of credentials stored on them, and says the vendor's integrity tool is not enough to rule out compromise (Confirmed [5]).
3. **Hunt for infostealer exposure and rotate what it found.** Mandiant recommends universal MFA, credential rotation, network allow lists and control of contractor devices (Confirmed [42]).
4. **Govern cloud applications and service principals.** Microsoft asks defenders to audit privileges of identities, service principals and apps, review apps holding broad mailbox roles, and hunt with audit logs because IP indicators are unreliable (Confirmed [132]).

5. **Log off the device and watch configuration.** The telecom guidance asks for a central configuration store with change alerting, secure centralized logging, out-of-band management and no internet-exposed management interfaces (Confirmed [77]).
6. **Stage your own updates, including security software.** CrowdStrike's commitments after 19 July were canary and staggered rollout and customer control of update timing; apply the same rule to every agent with kernel access (Confirmed [138]; Inferred for the generalization).

Scope and method

This study covers intrusions, exploited vulnerabilities, crime, outages and the government response in calendar year 2024. It draws on CISA, FBI, NSA and partner advisories, alerts and directives, the Cyber Safety Review Board, Treasury, the UK NCA, NCSC and government, Europol, the Federal Register, NIST, the White House archive, the European Commission, the Australian Federal Register of Legislation and UNODC, the victims' own statements and SEC filings (Microsoft, HPE, loanDepot, UnitedHealth Group, Live Nation, AT&T, Sonic Automotive, Halliburton, American Water, Krispy Kreme, Cloudflare, Dropbox, BeyondTrust, Synnovis), the vendors that observed the activity (Volexity, Mandiant, Microsoft, Cisco Talos, Palo Alto Networks and Unit 42, Fortinet, ConnectWise, Claroty, Sygnia, Google TAG, CrowdStrike, Qualys), the CVE, NVD and KEV records, the live MITRE ATT&CK record for Salt Typhoon and the library's own data files. Every source was opened on 11 November 2026. Quotations are kept to a few words. Tradecraft is described at the level the advisories use, by technique name and id; no exploit details, commands, payload strings or ransom notes are reproduced.

Grade	Meaning
Confirmed	A primary source was opened: the agency, the victim, the vendor that observed the activity, a CVE, NVD or KEV record, or the MITRE record itself
Reported	Known only through a secondary source or a vendor's estimate from its own dataset, attributed by name, such as a Chainalysis figure or a claim a vendor relays from others
Demonstrated	A reproduction exists: this study re-ran the check against the library's data files
Inferred	This study's own reasoning from the cited facts, labelled where it appears

How the record is routed:

- **Home studies.** Where another study in this series is the home for an event, this study gives one paragraph and a link: Change Healthcare (the Change Healthcare study), XZ Utils (the XZ Utils study) and the industrial events (the ICS attacks and advisories study). OpenSSH's regreSSHion has its home in the SSHole OpenSSH study.
- **Attribution language.** Each source's own words are carried through, because the strength varies: "high confidence" for Volt Typhoon's pre-positioning (AA24-038A), "has reason to believe" for UTA0178 as a Chinese nation-state-level actor (Volexity), "suspected espionage" with no origin assessed for UNC5221 (Mandiant), "PRC-affiliated actors" with no group name for the telecom campaign (FBI and CISA), "almost certainly part of the SVR" for APT29 (AA24-057A) and "hallmarks of a sophisticated state-sponsored actor" with no state named for ArcaneDoor (Talos) (Confirmed [13][2][84][75][87][91]; Inferred for the comparison). A vendor's name for a cluster (UTA0178, UNC5221, UTA0218, UNC5537, UNC5820,

UAT4356) is used with that vendor's report; its ATT&CK object is given only where the library's data carries the name or a campaign record ties it.

- **Victims who name no actor.** The loanDepot, Live Nation, AT&T, Sonic Automotive (CDK Global), Halliburton, American Water and Krispy Kreme filings name no actor, and the AT&T and Live Nation filings do not name Snowflake (Confirmed [11][43][44][46][57][67][80]). No ransomware group is tied here to Synnovis, CDK Global, Halliburton or Krispy Kreme, because no primary source opened for this study makes the tie.
- **Revised advisories.** AA24-109A (Akira) was updated on 13 November 2025 and its live tables print ATT&CK v18 ids and later CVEs; AA24-131A (Black Basta) was revised on 8 November 2024; AA23-353A (ALPHV Blackcat) was updated on 27 February 2024 (Confirmed [36][39][97]). Where a live page mixes later material into a 2024 advisory, this study says so and does not date the later material to 2024.
- **KEV dates and flags.** A KEV date-added value is the day CISA listed the CVE, not the day it was first exploited. The known-ransomware flag is revised after listing, so the 44 flags counted here reflect the catalog of November 2026, not what was known in 2024 (Confirmed [3]; Inferred for the caution).
- **ATT&CK versions.** The 2024 advisories print ATT&CK v14 to v18 ids. This study maps them to v20.0 through the library's `superseded_by.jsonl`, where T1562.001 becomes T1685 Disable or Modify Tools, T1562.004 becomes T1686 Disable or Modify System Firewall and T1070.001 becomes T1685.005 Clear Windows Event Logs (Confirmed [140]; Demonstrated [146]).
- **Events before 2024.** HPE's mailbox compromise (from May 2023), Midnight Blizzard's spray (from late November 2023), Cloudflare's Thanksgiving intrusion (23 November 2023), ArcaneDoor's infrastructure (from November 2023) and the Ivanti exploitation (from December 2023) began in 2023 but were disclosed or acted on in 2024, and appear on the date of the 2024 record. The Nearest Neighbor intrusion was detected in February 2022 and reported in November 2024 (Confirmed [6][7][1][91][2][88]).
- **What is overstated and what is understated.** This study's own reading of where the 2024 record misleads is set out under Cross-cutting themes, with the evidence for each point.
- **What was not checked.** The following reported events and documents were not opened at a primary source during the research and are left out of the dated record: the Ascension ransomware incident; the Transport for London incident; the Port of Seattle incident; the Internet Archive breach; PowerSchool, Rhode Island's RIBridges, Blue Yonder and the Cyberhaven browser extension; the MITRE NERVE intrusion; the AnyDesk production incident; the Treasury Departmental Offices compromise reported through BeyondTrust; National Public Data; the DOJ releases on the KV botnet disruption, the Flax Typhoon botnet disruption, the APT31 indictment, the Rim Jong Hyok indictment, the Iranian campaign-hack indictment, the LockBit developer charges, the Scattered Spider charges and the 911 S5 arrest; the joint ODNI, FBI and CISA statement on Iranian election influence; Microsoft's October 2024 Star Blizzard domain action beyond the release cited; Lumen's Versa Director report; the Huntress report on Cleo and any Cl0p attribution for Cleo; the ransomware groups behind Synnovis, Ascension, CDK Global and Port of Seattle; the ALPHV exit date; Dark Angels' victim; the EU Cyber Resilience Act and AI Act Official Journal texts; and the FCC Cyber Trust Mark. Their absence here is a gap in what was opened, not a judgment on what happened.

Part 1: the year at a glance

One row per dated event or report. Grades and sources are given on each row; later Parts tell the longer stories. "Unnamed" means the verified record names no actor.

Date	Event	Who (as the source names them)	Grade and source
2023-05 to 2023-12-12	HPE's cloud email accessed and data taken from a small percentage of mailboxes from May 2023; HPE notified 12 Dec 2023; 8-K filed 24 Jan 2024 [technology]	Midnight Blizzard, a suspected nation-state actor	Confirmed [6]
2023-10 to 2024-10-16	Password spraying and MFA push bombing against healthcare, government, IT, engineering and energy, likely to sell access (AA24-290A, 16 Oct)	Iranian actors	Confirmed [68]
2023-11 (late) to 2024-01-12	A password spray compromises a legacy non-production test tenant account at Microsoft; a very small percentage of corporate mailboxes read, including senior leadership, security and legal staff; detected 12 Jan, disclosed 19 Jan [technology]	Midnight Blizzard (Nobelium)	Confirmed [7][114]
2023-11-23 (event); 2024-02-01 (post)	Cloudflare detects an actor on its self-hosted Atlassian server, cuts access and engages CrowdStrike forensics on 26 Nov; no customer data or systems affected [internet infrastructure]	Unnamed	Confirmed [1]
2023-11 to 2024-04	ArcaneDoor: Cisco ASA devices on government networks backdoored with Line Runner and Line Dancer; infrastructure from Nov 2023, most activity Dec 2023 to Jan 2024; Talos report Apr 2024	UAT4356 (Microsoft STORM-1849); no state named	Confirmed [91]
2023-12 to 2024-01-10	Volexity traces web shells and lateral movement at a customer to Ivanti Connect Secure zero-days CVE-2023-46805 and CVE-2024-21887; KEV lists both the same day	UTA0178 (Volexity); UNC5221 (Mandiant); ATT&CK C0029 Cutting Edge	Confirmed [2][84][3]
2024-01	FrostyGoop uses Modbus TCP against a municipal energy company in Ukraine, cutting heating to over 600 apartment buildings; public in July	Unnamed; ATT&CK C0041	Confirmed [54]
2024-01-04 to 01-08	loanDepot identifies unauthorized access and encryption of data and shuts down certain systems [mortgage lending]	Unnamed	Confirmed [11]
2024-01-19	Emergency Directive 24-01: federal civilian agencies must mitigate Ivanti Connect Secure and Policy Secure	CISA	Confirmed [4][102]
2024-01-25	Microsoft's responder guidance on the Midnight Blizzard intrusion: OAuth application abuse and mail access	Midnight Blizzard	Confirmed [132]

Date	Event	Who (as the source names them)	Grade and source
2024-01-31	Ivanti SSRF CVE-2024-21893 added to KEV; Ivanti patches ship from this date	Exploited in the wild	Confirmed [3][101]
2024-02-02	Treasury sanctions six IRGC Cyber-Electronic Command officials after defacements of Unitronics PLC screens	IRGC-CEC	Confirmed [12]
2024-02-07	AA24-038A: Volt Typhoon pre-positioning in US critical infrastructure IT networks; footholds of at least five years	Volt Typhoon (PRC state-sponsored)	Confirmed [13]
2024-02-08 to 02-09	FortiOS SSL VPN CVE-2024-21762 potentially exploited in the wild; KEV next day	Unnamed	Confirmed [103][3]
2024-02-13 to 02-22	ConnectWise receives a report of a ScreenConnect authentication bypass (13 Feb), mitigates cloud instances; bulletin 19 Feb; CVE-2024-1709 in KEV 22 Feb with known ransomware use	Unnamed; later Black Basta per AA24-131A	Confirmed [20][3][39]
2024-02-14	Microsoft and OpenAI publish research on state actors' use of large language models	Several state actors	Confirmed [14]
2024-02-15	AA24-046A: a former employee's account leads to network administrator credentials, VPN access and LDAP queries at a state government organization	Unidentified actor	Confirmed [15]
2024-02-20	Operation Cronos: the NCA, FBI and partners take control of LockBit's administration environment and leak site; Treasury sanctions two affiliates	LockBit	Confirmed [93][16][17][94]
2024-02-21	Change Healthcare systems isolated after UnitedHealth identifies a suspected nation-state associated actor (the 8-K wording)	See the home study	Confirmed [21][22]
2024-02-26	AA24-057A: SVR actors adapt to cloud access by spraying service and dormant accounts. NIST releases CSF 2.0	APT29 (SVR); NIST	Confirmed [24][87][126]
2024-02-27	AA23-353A on ALPHV Blackcat updated	ALPHV Blackcat	Confirmed [97]
2024-02-28	Executive Order 14117 on bulk sensitive personal data	The White House	Confirmed [123]
2024-02-29	AA24-060A on Phobos; AA24-060B on chained Ivanti flaws and the failed integrity checker	Phobos; unnamed actors	Confirmed [25][5]
2024-03-04 to 03-07	JetBrains TeamCity CVE-2024-27198, reported by Rapid7; KEV 7 Mar with known ransomware use	Unnamed	Confirmed [104]
2024-03-05	Treasury sanctions two individuals and five entities of the Intellexa spyware consortium	Intellexa	Confirmed [26]

Date	Event	Who (as the source names them)	Grade and source
2024-03-08	Microsoft says Midnight Blizzard used stolen email to reach some source code repositories and internal systems; 8-K/A filed	Midnight Blizzard	Confirmed [8][9][115]
2024-03-12 to 03-25	FortiClient EMS SQL injection CVE-2023-48788; KEV 25 Mar with known ransomware use	Unnamed	Confirmed [105]
2024-03-20	Cyber Safety Review Board report on the 2023 Exchange Online intrusion: preventable, and a security culture that needs an overhaul	Storm-0558 (2023)	Confirmed [117]
2024-03-25	UK attributes the Electoral Commission compromise to a Chinese state-affiliated entity and APT31 reconnaissance of parliamentarians; Treasury and the UK sanction Wuhan XRZ and two APT31-linked nationals	A Chinese state-affiliated entity (Electoral Commission); APT31 (ZIRCONIUM) for the reconnaissance and the sanctions	Confirmed [27][28]
2024-03-26 to 04-12	PAN-OS GlobalProtect CVE-2024-3400: test exploitation from 26 Mar, zero-day use at a customer 10 Apr; advisory and KEV 12 Apr	UTA0218; ATT&CK C0048 Operation MidnightEclipse	Confirmed [32][33][3]
2024-03-29	Andres Freund reports backdoored xz 5.6.0 and 5.6.1; CISA alert; CVE-2024-3094, not in KEV	See the home study	Confirmed [29][30][113]
2024-04-04	CIRCIA reporting requirements proposed rule published	CISA	Confirmed [124]
2024-04-11	Emergency Directive 24-02 on Microsoft corporate email; CISA alert on the Sisense customer data compromise	CISA	Confirmed [10][31]
2024-04-12	Claroty analyzes Blackjack's Fuxnet attack on Moscow sensor gateways	Blackjack (group claim)	Confirmed [34]
2024-04-14 to 04-25	Files taken from an AT&T workspace on a third-party cloud platform: call and text records of nearly all wireless customers; 8-K filed 12 Jul [telecommunications]	Unnamed	Confirmed [44]
2024-04-17	Mandiant names Sandworm APT44 and warns of election interference risk	Sandworm Team (APT44)	Confirmed [35]
2024-04-18	AA24-109A on Akira	Akira	Confirmed [36]
2024-04-22	UnitedHealth says PHI or PII found could cover a substantial proportion of people in America. CrushFTP CVE-2024-4040 (KEV 24 Apr)	See the home study; unnamed	Confirmed [23][106]
2024-04-23	Treasury sanctions two companies and four individuals acting for IRGC-CEC	IRGC-CEC	Confirmed [37]
2024-04-24	Dropbox learns of unauthorized access to the Dropbox Sign production environment. ArcaneDoor CVEs in KEV	Unnamed; UAT4356	Confirmed [38][91][3]

Date	Event	Who (as the source names them)	Grade and source
2024-04-29	UK PSTI regime in force, banning weak default passwords	UK government	Confirmed [128]
2024-04-30	NSM-22 on critical infrastructure security and resilience	The White House	Confirmed [125]
2024-05-01	Fact sheet: pro-Russia hacktivists manipulate small-scale ICS in water, dams, energy and food	Pro-Russia hacktivists	Confirmed [118]
2024-05-07	LockBitSupp named as Dmitry Khoroshev and sanctioned by the US, UK and Australia	LockBit	Confirmed [18][19]
2024-05-08	CISA's Secure by Design pledge launches with 68 manufacturers	CISA	Confirmed [139]
2024-05-10	AA24-131A on Black Basta	Black Basta affiliates	Confirmed [39]
2024-05-20 to 05-27	Live Nation identifies unauthorized activity in a third-party cloud database environment (mainly Ticketmaster data); data offered for sale 27 May [entertainment]	A criminal actor	Confirmed [43]
2024-05 (late)	Operation Endgame against IcedID, SystemBC, Pikabot, Smokeloader, Bumblebee and Trickbot	Europol and partners	Confirmed [40]
2024-05-28	Treasury sanctions the 911 S5 botnet's administrator and associates. Microsoft names Moonstone Sleet. Check Point CVE-2024-24919 (KEV 30 May)	911 S5; Moonstone Sleet; unnamed	Confirmed [95][90][107][136]
2024-06-02 to 06-03	Snowflake notices increased threat activity against customer accounts; CISA relays it	UNC5537 (Mandiant)	Confirmed [41]
2024-06-03	Synnovis cyberattack affects all its IT systems and disrupts pathology services [healthcare]. Sygnia reports Velvet Ant on F5 load balancers	Unnamed; Velvet Ant	Confirmed [45][85]
2024-06-09 to 06-12	PHP-CGI on Windows CVE-2024-4577; KEV 12 Jun with known ransomware use	Unnamed	Confirmed [108]
2024-06-10	Mandiant: UNC5537 used infostealer credentials against Snowflake customer instances; about 165 organizations notified	UNC5537	Confirmed [42]
2024-06-18	Mandiant's report on UNC3886 espionage operations	UNC3886	Confirmed [86]
2024-06-19	CDK Global suspends systems after a cybersecurity incident; Sonic Automotive's dealer system disrupted [automotive retail]	Unnamed	Confirmed [46]
2024-06-24	Commerce final determination bars Kaspersky from new US agreements from 20 Jul and from updates and resale from 29 Sep	Commerce BIS	Confirmed [121]

Date	Event	Who (as the source names them)	Grade and source
2024-06-26	Cloudflare rewrites polyfill.io links to its own mirror after reports that the service injected malicious JavaScript	Domain owner after a February 2024 sale (Reported)	Confirmed [47]; Reported [47]
2024-06-27	FortiManager CVE-2024-47575 exploited from this date (disclosed 23 Oct)	UNC5820	Confirmed [69]
2024-07-01	Qualys discloses regreSSHion, CVE-2024-6387, in OpenSSH sshd; not in KEV	n/a	Confirmed [48][137]
2024-07-08	AA24-190A on APT40 tradecraft	APT40 (Leviathan)	Confirmed [49]
2024-07-18	SEC v. SolarWinds: the court grants in part and denies in part the motion to dismiss	SEC; SolarWinds	Confirmed [122]
2024-07-19	CrowdStrike content update crashes Windows hosts (04:09 to 05:27 UTC); about 8.5 million devices. Treasury sanctions two CARR members	n/a; Cyber Army of Russia Reborn	Confirmed [50][51][52][53]
2024-07-25	AA24-207A on Andariel; Mandiant names APT45	Andariel (Onyx Sleet); APT45	Confirmed [55][56]
2024-07-29 to 07-30	ESXi CVE-2024-37085 abused before Akira and Black Basta deployments; KEV 30 Jul	Storm-0506, Storm-1175, Octo Tempest, Manatee Tempest	Confirmed [109]
2024-08-13	NIST publishes FIPS 203, 204 and 205	NIST	Confirmed [127]
2024-08-14	Google TAG on APT42's targeting of the US presidential election	APT42	Confirmed [89]
2024-08-21	Halliburton learns of unauthorized access, takes systems offline and believes data was exfiltrated [energy services]	Unauthorized third party	Confirmed [57][58]
2024-08-28	AA24-241A: Iran-based actors sell access and work with ransomware affiliates	Pioneer Kitten (Fox Kitten)	Confirmed [59]
2024-08-29	AA24-242A on RansomHub: at least 210 victims since February	RansomHub	Confirmed [60]
2024-09-05	AA24-249A: GRU Unit 29155 espionage, sabotage and reputational harm	Ember Bear	Confirmed [61]
2024-09-07 to 10-17	Veeam Backup & Replication CVE-2024-40711; KEV 17 Oct with known ransomware use	Unnamed	Confirmed [110]
2024-09-18	Joint advisory on a botnet of over 260,000 devices run by Integrity Technology Group	Flax Typhoon (FBI's consistency finding)	Confirmed [62][82]
2024-09-25	CISA: exploitation of internet-accessible OT continues, including in water	Unnamed	Confirmed [119]
2024-09-26	Microsoft: Storm-0501 ransomware attacks extend into hybrid cloud	Storm-0501	Confirmed [63]

Date	Event	Who (as the source names them)	Grade and source
2024-09-27	Treasury designates seven individuals for Iranian election interference	IRGC members	Confirmed [64]
2024-10-01	Evil Corp designations by the US, UK and Australia; Cronos phase three arrests	Evil Corp; LockBit	Confirmed [65][96]
2024-10-03	Microsoft's court order seizes 66 Star Blizzard domains. American Water learns of unauthorized activity [water utility]	Star Blizzard; unnamed	Confirmed [66][67]
2024-10-17	NIS2 transposition deadline	EU Member States	Confirmed [129]
2024-10-23	Fortinet FG-IR-24-423 and Mandiant on FortiManager exploitation; KEV the same day	UNC5820	Confirmed [70][69][3]
2024-10-28	Operation Magnus disrupts RedLine and META	Dutch National Police, FBI and partners	Confirmed [72]
2024-10-31	CISA warns of large-scale spearphishing with malicious RDP attachments	Midnight Blizzard (Microsoft); APT29 (AWS)	Confirmed [73]
2024-11-08 to 11-18	PAN-OS CVE-2024-0012 chained with CVE-2024-9474; KEV 18 Nov with known ransomware use	Unnamed	Confirmed [111]
2024-11-12	AA24-317A: the top routinely exploited vulnerabilities of 2023	Five Eyes agencies	Confirmed [74]
2024-11-13	FBI and CISA: PRC-affiliated actors compromised multiple telecommunications companies	PRC-affiliated actors (Salt Typhoon binding Inferred)	Confirmed [75]; Inferred [83]
2024-11-22	Volexity's Nearest Neighbor report on a 2022 intrusion through nearby Wi-Fi networks	GruesomeLarch (APT28)	Confirmed [88]
2024-11-29	Krispy Kreme notified of unauthorized activity; online ordering disrupted [food retail]. Australia's Cyber Security Act 2024	Unnamed; Australian Parliament	Confirmed [80][130]
2024-12-02 to 12-19	BeyondTrust confirms anomalous behavior in Remote Support SaaS on 5 Dec; an infrastructure API key exposed; CVE-2024-12356 in KEV 19 Dec	Unnamed	Confirmed [81][3]
2024-12-03 to 12-04	Enhanced Visibility and Hardening Guidance for Communications Infrastructure	CISA, NSA, FBI and partners	Confirmed [76][77]
2024-12-04	Microsoft: Secret Blizzard uses Storm-0156's infrastructure for its own espionage	Secret Blizzard (Turla)	Confirmed [78]
2024-12-10	Treasury sanctions Sichuan Silence and an employee over the April 2020 firewall compromise	Sichuan Silence	Confirmed [79]
2024-12-13 to 12-17	Cleo CVE-2024-50623 and CVE-2024-55956 in KEV, both with known ransomware use	Unnamed (Cl0p attribution not checked)	Confirmed [3][112]

Date	Event	Who (as the source names them)	Grade and source
2024-12-24	UN General Assembly adopts the Convention against Cybercrime	UN	Confirmed [131]

Part 2: the edge-device year

Ivanti Connect Secure. Volexity detected web shells and lateral movement at a customer in the second week of December 2023 and traced them to two zero-days in Ivanti Connect Secure, CVE-2023-46805 and CVE-2024-21887; in its post of 10 January it tracks the actor as UTA0178 and says it "has reason to believe" UTA0178 is a Chinese nation-state-level actor (Confirmed [2]). Mandiant tracked the same exploitation, from as early as December 2023, as UNC5221, a "suspected espionage" actor, and said at publication it lacked the data to assess the actor's origin (Confirmed [84]). ATT&CK records the campaign as C0029 Cutting Edge (Confirmed [84]; Demonstrated [143]). NVD lists CWE-287 for CVE-2023-46805 and CWE-77 for CVE-2024-21887; both entered KEV on 10 January and both now carry the known-ransomware flag (Confirmed [144][3]). Ivanti's advisory adds CVE-2024-21888 and CVE-2024-21893, a server-side request forgery (CWE-918) in the SAML component, with patches shipping from 31 January; KEV listed CVE-2024-21893 that day (Confirmed [101][145][3]). Emergency Directive 24-01 of 19 January told federal civilian agencies to apply the mitigation, remove compromised products and apply updates within 48 hours of release (Confirmed [4][102]). AA24-060B of 29 February says actors chained all three CVEs, that Ivanti's internal and external Integrity Checker Tool failed to detect compromise in CISA's incident responses, and that CISA's own lab research showed root-level persistence could survive a factory reset; it calls the tool not sufficient to detect compromise and asks organizations to weigh the risk of continuing to run the gateways (Confirmed [5]).

ConnectWise ScreenConnect. ConnectWise received a report of an authentication bypass on 13 February, validated it on 14 February, mitigated its cloud instances within 48 hours and told on-premises partners to upgrade; its bulletin is dated 19 February (Confirmed [20]). CVE-2024-1709 carries CVSS 10.0; the CNA lists CWE-288 and NVD lists NVD-CWE-Other; KEV listed it on 22 February with known ransomware use (Confirmed [20][133][3]). AA24-131A names it among Black Basta's initial access routes from February 2024 (Confirmed [39]).

Palo Alto Networks, twice. Volexity saw zero-day exploitation of PAN-OS GlobalProtect at a customer on 10 April, found test exploitation back to 26 March, tracks the actor as UTA0218, and saw it export device configuration, move laterally and deploy the UPSTYLE Python backdoor (Confirmed [32]). Palo Alto Networks' advisory of 12 April describes CVE-2024-3400 as command injection allowing unauthenticated root code execution, discovered in production use (Confirmed [33]). NVD lists CWE-77 and the CNA lists CWE-20 and CWE-77, CVSS 10.0; KEV listed it on its publication day with known ransomware use (Confirmed [134][3]). ATT&CK records the campaign as C0048 Operation MidnightEclipse and the backdoor as S1164 UPSTYLE (Confirmed [32]; Demonstrated [143][92]). In November, PAN-SA-2024-0015, first published on 8 November, became CVE-2024-0012 (CWE-306) chained with CVE-2024-9474 (CWE-78); Palo Alto Networks raised its severity on 14 November after observing threat activity, and KEV listed both on 18 November with known ransomware use (Confirmed [111]).

ArcaneDoor and Cisco ASA. Cisco Talos describes UAT4356 (Microsoft's STORM-1849) using CVE-2024-20353 (CWE-835) and CVE-2024-20359 (CWE-94) on Cisco ASA devices in government

networks, with the Line Runner and Line Dancer backdoors; actor infrastructure dates from November 2023 and most activity from December 2023 to January 2024 (Confirmed [91]). Talos says the tooling shows hallmarks of a sophisticated state-sponsored actor but names no state, and the initial access vector was not determined (Confirmed [91]). KEV listed both CVEs on 24 April (Confirmed [91][3]). ATT&CK records C0046 ArcaneDoor, S1188 Line Runner and S1186 Line Dancer (Demonstrated [143][92]).

Fortinet. FortiOS SSL VPN CVE-2024-21762 (CWE-787) was "potentially being exploited in the wild" per Fortinet's FG-IR-24-015 of 8 February and was in KEV the next day (Confirmed [103]). FortiClient EMS CVE-2023-48788, a SQL injection (CWE-89), entered KEV on 25 March with known ransomware use (Confirmed [105]). FortiManager CVE-2024-47575 is missing authentication for a critical function (CWE-306) in the fgfmd daemon, exploited in the wild per FG-IR-24-423; KEV listed it on 23 October (Confirmed [70][135][3]). Mandiant says UNC5820 exploited it as early as 27 June, staging and exfiltrating configuration data of the FortiGate devices the FortiManager managed (Confirmed [69]). CISA noted on 30 October that Fortinet had updated its advisory with workarounds and indicators and that all patches were out (Confirmed [71]).

The rest of the year's edge and server flaws. JetBrains TeamCity CVE-2024-27198 (CWE-288), reported by Rapid7, entered KEV on 7 March with known ransomware use (Confirmed [104]). CrushFTP CVE-2024-4040 (CWE-1336, CWE-94), an unauthenticated template injection, entered KEV on 24 April (Confirmed [106]). Check Point CVE-2024-24919, an information disclosure (CNA CWE-200) fixed by hotfix sk182336, entered KEV on 30 May with known ransomware use (Confirmed [107][136]). PHP-CGI on Windows CVE-2024-4577 (CWE-78) entered KEV on 12 June with known ransomware use (Confirmed [108]). Microsoft says Storm-0506, Storm-1175, Octo Tempest (G1015) and Manatee Tempest (G0119) abused ESXi CVE-2024-37085 (CWE-287, CWE-305), leading to Akira and Black Basta deployments; KEV listed it on 30 July with known ransomware use (Confirmed [109]). Veeam Backup & Replication CVE-2024-40711 (CWE-502, CVSS 9.8) is unauthenticated remote code execution and entered KEV on 17 October with known ransomware use (Confirmed [110]). Cleo Harmony, VLTrader and LexiCom CVE-2024-50623 (CWE-434) and CVE-2024-55956 (CWE-77) entered KEV on 13 and 17 December, both with known ransomware use; who exploited them was not checked (Confirmed [112][3]). BeyondTrust confirmed anomalous behavior in its Remote Support SaaS on 5 December: a zero-day in a third-party application gave access to an infrastructure API key; it announced CVE-2024-12356 on 16 December, KEV listed it on 19 December, and BeyondTrust says no ransomware was involved (Confirmed [81][3]).

OpenSSH regreSSHion, in one paragraph. The home for OpenSSH flaws in this series is the SSHole OpenSSH study. Qualys disclosed CVE-2024-6387 on 1 July: a signal-handler race in sshd on glibc Linux that regresses CVE-2006-5051 and affects the default configuration (Confirmed [48]). The CNA lists CWE-364 and NVD lists CWE-362; it is not in KEV as of catalog 2026.11.10 (Confirmed [137][3]).

KEV in numbers. Computed from the KEV catalog (version 2026.11.10, 1,779 entries), 186 entries were added in 2024, and 44 of them are flagged for known ransomware use today; the vendors with the most additions were Microsoft (36), Ivanti (11), Google (9), Adobe (8), Palo Alto Networks (7) and Apple (7), and the most common CWEs were CWE-78 (14), CWE-502 (11), CWE-416 (10), CWE-22 (9) and CWE-287 (9) (Confirmed [3]). Other KEV-dated 2024 rows the research recorded, whose vendor advisories were not opened, are Linux kernel CVE-2024-1086 (30 May), Windows CVE-2024-38193 (13 Aug), Versa Director CVE-2024-39717 (23 Aug), SonicWall CVE-2024-40766 (9 Sep), Ivanti CSA CVE-2024-8963 (19 Sep), Ivanti vTM CVE-2024-7593 (24 Sep) and Fortinet CVE-2024-23113 (9 Oct) (Confirmed [3]). The year's headline

additions, in date order:

CVE	Product	What the record says	KEV added	Source
CVE-2023-46805, CVE-2024-21887	Ivanti Connect Secure and Policy Secure	Authentication bypass (CWE-287) and command injection (CWE-77); zero-days from December 2023; known ransomware use	2024-01-10	Confirmed [2][144][3]
CVE-2024-21893	Ivanti Connect Secure (SAML)	SSRF (CWE-918), the third link in the chain	2024-01-31	Confirmed [145][5]
CVE-2024-21762	FortiOS SSL VPN	Out-of-bounds write (CWE-787); potentially exploited	2024-02-09	Confirmed [103]
CVE-2024-1709	ConnectWise ScreenConnect	Authentication bypass (CNA CWE-288), CVSS 10.0; known ransomware use	2024-02-22	Confirmed [20][133]
CVE-2024-27198	JetBrains TeamCity	CWE-288; known ransomware use	2024-03-07	Confirmed [104]
CVE-2023-48788	FortiClient EMS	SQL injection (CWE-89); known ransomware use	2024-03-25	Confirmed [105]
CVE-2024-3400	PAN-OS GlobalProtect	Command injection (CWE-77; CNA also CWE-20), CVSS 10.0; known ransomware use	2024-04-12	Confirmed [33][134]
CVE-2024-20353, CVE-2024-20359	Cisco ASA and FTD	Loop with unreachable exit (CWE-835) and code injection (CWE-94); ArcaneDoor	2024-04-24	Confirmed [91]
CVE-2024-4040	CrushFTP	Template injection (CWE-1336, CWE-94)	2024-04-24	Confirmed [106]
CVE-2024-24919	Check Point Quantum gateways	Information disclosure (CNA CWE-200); known ransomware use	2024-05-30	Confirmed [107][136]
CVE-2024-4577	PHP-CGI on Windows	OS command injection (CWE-78); known ransomware use	2024-06-12	Confirmed [108]
CVE-2024-37085	VMware ESXi	Authentication bypass (CWE-287, CWE-305); known ransomware use	2024-07-30	Confirmed [109]
CVE-2024-40711	Veeam Backup & Replication	Deserialization (CWE-502), CVSS 9.8; known ransomware use	2024-10-17	Confirmed [110]
CVE-2024-47575	FortiManager	Missing authentication (CWE-306); exploited from June	2024-10-23	Confirmed [70][135][69]
CVE-2024-0012, CVE-2024-9474	PAN-OS management interface	Missing authentication (CWE-306) and OS command injection (CWE-78); known ransomware use	2024-11-18	Confirmed [111]
CVE-2024-50623, CVE-2024-55956	Cleo Harmony, VLTrader, LexiCom	Unrestricted upload (CWE-434) and command injection (CWE-77); known ransomware use	2024-12-13, 2024-12-17	Confirmed [112][3]
CVE-2024-12356	BeyondTrust Remote Support	Announced 16 Dec after the SaaS investigation	2024-12-19	Confirmed [81][3]

Two widely reported 2024 CVEs are not in KEV: CVE-2024-3094 (XZ Utils) and CVE-2024-6387 (regreSSHion) (Confirmed [3]).

What was exploited most. AA24-317A, published on 12 November 2024 by the Five Eyes agencies, lists the top routinely exploited vulnerabilities of 2023, led by Citrix CVE-2023-3519 and CVE-2023-4966; it says malicious actors exploited more zero-days against enterprise networks in 2023 than in 2022, that most of the most frequently exploited vulnerabilities of 2023 were first exploited as zero-days against fewer than half in 2022, and that the list, dominated by edge and file-transfer products, still includes Log4Shell and MOVEit (Confirmed [74]). The Log4Shell record behind its place on that list is in the Log4Shell study and the MOVEit campaign in the Cl0p file-transfer study. The advisory asks vendors to eliminate repeatedly exploited vulnerability classes, prefer memory-safe languages, remove default passwords and publish correct CWEs, and asks defenders to patch KEV and internet-facing critical vulnerabilities first and to check for compromise before patching (Confirmed [74]).

Part 3: China

The wider record is in the China-attributed actors study, and APT41's in the APT41 public record study. This Part gives the 2024 sequence.

Volt Typhoon. AA24-038A of 7 February, from CISA, NSA and FBI with DOE, EPA, TSA and the Australian, Canadian, UK and New Zealand agencies, names Volt Typhoon (G1017) as PRC state-sponsored and assesses with high confidence that it is pre-positioning on IT networks to enable lateral movement to OT assets and disrupt functions primarily in Communications, Energy, Transportation Systems and Water and Wastewater, in the continental US and in territories including Guam (Confirmed [13]). It says the actors held access and footholds in some victim IT environments for at least five years, calls living off the land a hallmark of their activity, and names FortiGate CVE-2022-42475 as a likely initial access vector (Confirmed [13]). The advisory says the actors used end-of-life Cisco and NETGEAR SOHO routers implanted with KV Botnet malware (T1584.005); ATT&CK records C0035 KV Botnet Activity (Confirmed [13]; Demonstrated [143]). Its technique tables cover more than fifty Enterprise techniques; the research read the page to character 100,000 of 132,303, so the appendix tables were only partly read, and Part 13 binds the ids that were read (Confirmed [13]). The top mitigations put patching internet-facing systems, KEV entries and edge appliances first, then phishing-resistant MFA, no credentials stored on edge devices, least privilege, limited RDP, centralized logging, OT segmentation and replacement of end-of-life devices (Confirmed [13]). ATT&CK also records C0039 Versa Director Zero Day Exploitation for Volt Typhoon in June to August 2024; its primary report could not be opened, so it is named here and not bound (Demonstrated [143]).

APT31 and the UK Electoral Commission. On 25 March the UK said the NCSC assesses the Electoral Commission's systems were highly likely compromised by a Chinese state-affiliated entity between late 2021 and October 2022, and that APT31 almost certainly ran reconnaissance against UK parliamentarians in a separate 2021 campaign, with no parliamentary accounts compromised; the UK summoned the Chinese Ambassador and sanctioned a front company and two APT31 members (Confirmed [27]). The Electoral Commission compromise is not attributed to APT31 by name (Confirmed [27]). Treasury designated Wuhan Xiaoruizhi Science and Technology Co. (Wuhan XRZ), which it describes as an MSS front company set up by the Hubei State Security Department in 2010, and Zhao Guangzong and Ni Gaobin as APT31-affiliated, for operations against US critical infrastructure entities; the same day DOJ unsealed indictments against them and five others and State offered a reward (Confirmed [28]). In ATT&CK, APT31 is an alias of G0128 ZIRCONIUM (Demonstrated [92]).

APT40. AA24-190A of 8 July, led by ASD's ACSC with CISA, NSA, FBI and partners, covers APT40, previously reported as based in Haikou and tasked by the MSS Hainan State Security Department (Confirmed [49]). It says the group rapidly adapts public proof-of-concept exploits, exploits new public vulnerabilities within hours or days, prefers public-facing infrastructure to phishing, uses web shells (T1505.003), targets end-of-life devices and uses compromised SOHO devices as last-hop redirectors (T1584.008) (Confirmed [49]). In ATT&CK, APT40 is G0065 Leviathan (Demonstrated [92]).

Velvet Ant and UNC3886. Sygnia reported on 3 June that the China-nexus group Velvet Ant (G1047) abused F5 load balancers for persistence during a prolonged intrusion at a large organization (Confirmed [85]). Mandiant's 18 June report describes UNC3886 (G1048) as a suspected China-nexus espionage actor it has investigated since finding ESXi hypervisor malware in September 2022 (Confirmed [86]).

Flax Typhoon and the botnet. An FBI, CNMF and NSA advisory of 18 September (JCSA-20240918-001) says Integrity Technology Group, a PRC-based company, ran a botnet from mid-2021 that held over 260,000 devices as of June 2024; the FBI found the activity consistent with the group known publicly as Flax Typhoon, RedJuliett and Ethereal Panda, with the caveat that vendor groupings may not map 1:1 to the US Government's (Confirmed [82]). The NCSC and partners describe the same botnet of compromised routers, firewalls and IoT devices (Confirmed [62]). Lumen's Black Lotus Labs calls the botnet Raptor Train, assesses it is likely run by Flax Typhoon, and counts over 60,000 active devices at its June 2023 peak and more than 200,000 conscripted over time (Reported [120]). The library has no Flax Typhoon group object, so it stays unlinked (Demonstrated [92]).

The telecom campaign. A joint FBI and CISA statement of 13 November says PRC-affiliated actors compromised multiple telecommunications companies in a broad and significant cyber espionage campaign, enabling theft of customer call records, compromise of the private communications of a limited number of people mainly in government or political activity, and copying of information subject to US law enforcement requests under court orders (Confirmed [75]). On 3 and 4 December, CISA, NSA, FBI, ASD's ACSC, CCCS and NCSC-NZ issued Enhanced Visibility and Hardening Guidance for Communications Infrastructure, which says the exploitation matched existing weaknesses with no novel activity observed as of release (Confirmed [76][77]). Neither statement uses the name Salt Typhoon (Confirmed [75][77]). ATT&CK's G1045 Salt Typhoon describes a PRC state-backed actor, active since at least 2019, that compromised US telecom and ISP network infrastructure through public-facing edge devices; binding the 2024 statements to G1045 is this study's reading from the ATT&CK record, not the CISA pages of that year (Inferred [83][92]).

Sichuan Silence. On 10 December Treasury sanctioned Sichuan Silence Information Technology Co. and employee Guan Tianfeng over the compromise of about 81,000 firewalls through a zero-day between 22 and 25 April 2020, which included attempted Ragnarok ransomware; DOJ unsealed an indictment and Rewards for Justice offered up to US$10 million (Confirmed [79]). The 2020 event itself is in the 2020 chronicle.

Part 4: Russia

The wider record is in the Russia-attributed actors study, and Sandworm's in the Sandworm study. APT29's earlier supply-chain operation is in the SolarWinds study.

Midnight Blizzard at Microsoft. Microsoft detected a nation-state attack on its corporate systems on 12 January and attributes it to Midnight Blizzard, the Russian state-sponsored actor also known as Nobelium; from late November 2023 a password spray compromised a legacy non-production test tenant account, whose

permissions the actor used to access a very small percentage of corporate email, including senior leadership, cybersecurity and legal staff, and to exfiltrate some emails (Confirmed [7][114]). Microsoft disclosed it in a Form 8-K filed on 19 January (Confirmed [114]). On 25 January Microsoft's responder guidance said the sprayed account had no MFA; the actor used residential proxies and few attempts per account, then abused a legacy test OAuth application, created OAuth applications and a user to consent to them, granted the Exchange Online full_access_as_app role and read mail through Exchange Web Services (Confirmed [132]). On 8 March Microsoft said the actor had used information from the exfiltrated email to access some source code repositories and internal systems, with no evidence that customer-facing systems were compromised (Confirmed [8]). The 8-K/A filed that day says the actor continues to try to use the information, that password-spray volume rose as much as tenfold in February, that some secrets customers had shared with Microsoft by email were exposed, and that the response requires a sustained, significant commitment of resources (Confirmed [9][115]). CISA's Emergency Directive 24-02, announced on 11 April, told federal civilian agencies to analyze email exfiltrated from Microsoft corporate accounts and reset compromised credentials, with resets due by 30 April; the directive is now marked closed (Confirmed [10][116]). In the library, Midnight Blizzard is an alias of G0016 APT29 (Demonstrated [92]).

Midnight Blizzard at HPE. HPE's 8-K, filed 24 January, says it was notified on 12 December 2023 that a suspected nation-state actor, believed to be Midnight Blizzard, had accessed its cloud-based email environment and taken data from a small percentage of mailboxes from May 2023 (Confirmed [6]).

SVR in the cloud. AA24-057A of 26 February, led by the UK NCSC with NSA, CISA, CNMF, FBI, ASD's ACSC, CCCS and NCSC-NZ, assesses APT29 as almost certainly part of the SVR and reports targeting expanded to aviation, education, law enforcement, local and state councils, government financial departments and the military (Confirmed [87][24]). Its techniques include brute force and password spraying of service and dormant accounts (T1110) and use of system-issued tokens (T1528) (Confirmed [87]). On 31 October CISA warned of a large-scale spearphishing campaign with malicious RDP attachments against government and IT, citing Microsoft's Midnight Blizzard and AWS's APT29 reporting (Confirmed [73]).

Sandworm becomes APT44. On 17 April Mandiant graduated Sandworm (FROZENBARENTS) to APT44, called it the Russian group most central to Moscow's military campaign, described it as sponsored by Russian military intelligence with sabotage not limited to military objectives, and warned of election interference risk in 2024 (Confirmed [35]). The page as opened gives no GRU unit number (Confirmed [35]). In ATT&CK this is G0034 Sandworm Team, which lists APT44 as an alias (Demonstrated [92]).

GRU Unit 29155. AA24-249A of 5 September, from the FBI, CISA, NSA and partners, assesses that actors affiliated with GRU Unit 29155 have conducted espionage, sabotage and reputational harm operations since at least 2020, deployed WhisperGate against Ukrainian organizations from 13 January 2022, and are separate from Units 26165 and 74455 (Confirmed [61]). In ATT&CK this is G1003 Ember Bear, with S0689 WhisperGate (Confirmed [61]; Demonstrated [92]).

APT28 and the nearest neighbor. Volexity's report of 22 November, about an intrusion it detected on 4 February 2022, ties the breach to GruesomeLarch (publicly APT28): the actor validated credentials by password spray, then used them on an enterprise Wi-Fi network without MFA that it reached by chaining compromises of nearby organizations, and sought data on Ukraine expertise (Confirmed [88]). ATT&CK records G0007 APT28 and C0051 APT28 Nearest Neighbor Campaign (Confirmed [88]; Demonstrated [143]).

Star Blizzard and Secret Blizzard. On 3 October a Microsoft Digital Crimes Unit court order allowed the seizure of 66 domains used by Star Blizzard (G1033), which targeted over 30 civil society organizations

between January 2023 and August 2024 (Confirmed [66]). On 4 December Microsoft reported that Secret Blizzard, which the library carries as an alias of G0010 Turla, had compromised the infrastructure of the Pakistan-based actor Storm-0156 to run its own espionage (Confirmed [78]; Demonstrated [92]).

Cyber Army of Russia Reborn. On 19 July Treasury sanctioned the leader and a primary hacker of Cyber Army of Russia Reborn for operations against US critical infrastructure (Confirmed [53]). CARR has no ATT&CK object in the library (Demonstrated [92]); its industrial activity belongs to the ICS attacks and advisories study.

Part 5: Iran and North Korea

The wider records are in the Iran-attributed actors study and the North Korea-attributed actors study.

IRGC-CEC and the PLC screens. On 2 February Treasury sanctioned six officials of the IRGC Cyber-Electronic Command after IRGC-affiliated actors hacked and posted images on Unitronics PLC screens used in water and other critical infrastructure in the US and other countries; Treasury says no critical services were disrupted (Confirmed [12]). On 23 April Treasury sanctioned two companies and four individuals acting for the IRGC-CEC that targeted more than a dozen US companies and government entities (Confirmed [37]). CyberAv3ngers is G1027 in the library's ICS data but has no generated page, so it stays unlinked (Demonstrated [92]).

Access for sale. AA24-241A of 28 August says Iran-based actors associated with the Government of Iran, known as Pioneer Kitten, Fox Kitten, UNC757, Parisite, RUBIDIUM and Lemon Sandstorm, obtain access to US organizations, sell it, and work with the NoEscape, Ransomhouse and ALPHV ransomware affiliates for a share of ransom payments (Confirmed [59]). In ATT&CK this is G0117 Fox Kitten (Demonstrated [92]). AA24-290A of 16 October says that since October 2023 Iranian actors have used password spraying and MFA push bombing against healthcare, government, IT, engineering and energy organizations, likely to sell access (Confirmed [68]).

The election. Google TAG describes APT42 (G1044) as an Iranian government-backed actor associated with the IRGC and confirms it targeted accounts linked to the US presidential election; the US and Israel were about 60% of its known targeting over six months, including people affiliated with both campaigns, with heavy credential phishing from February to late July 2024 (Confirmed [89]). On 27 September Treasury designated seven individuals over Iranian election interference: IRGC members compromised accounts of officials and advisors to a 2024 presidential campaign and leaked stolen data to media, with targeting increased since at least May 2024 (Confirmed [64]).

Andariel. AA24-207A of 25 July, from the FBI with partners including South Korea's NIS and NPA and the UK NCSC, says Andariel, also known as Onyx Sleet, a DPRK state-sponsored group under the RGB 3rd Bureau, runs global espionage against defense, aerospace, nuclear and engineering entities and funds it with ransomware against US healthcare; it gains initial access by exploiting known web server flaws such as Log4j to deploy web shells (Confirmed [55]). In ATT&CK this is G0138 Andariel (Demonstrated [92]). The Log4j exploitation is the long tail told in the Log4Shell study.

APT45 and Moonstone Sleet. Mandiant named APT45 on 25 July as a North Korean operator active since 2009 that expanded into financially motivated operations and is the DPRK group most often seen targeting critical infrastructure (Confirmed [56]). APT45 has no ATT&CK object in the library (Demonstrated [92]). On 28 May Microsoft identified Moonstone Sleet (G1036, formerly Storm-1789), which uses fake companies,

trojanized tools and a malicious game; in April 2024 it deployed the custom ransomware FakePenny against a company it had compromised in February, the first ransomware Microsoft has seen from this actor (Confirmed [90]).

Part 6: identity, the cloud and the help desk

Snowflake customer instances. Snowflake's notice of 2 June reported increased threat activity against customer accounts, and CISA relayed it the next day (Confirmed [41]). Mandiant's report of 10 June says the financially motivated UNC5537 compromised Snowflake customer instances with stolen customer credentials, mainly from infostealer infections on non-Snowflake systems, for data theft and extortion; Mandiant and Snowflake notified about 165 potentially exposed organizations, its first lead came in April 2024, and it found no evidence of a breach of Snowflake's enterprise environment (Confirmed [42]). At least 79.7 percent of the accounts used had prior credential exposure, the earliest linked infostealer infection dates to November 2020, the accounts had no MFA, some credentials had not been rotated for up to four years and the instances lacked network allow lists (Confirmed [42]). Mandiant names the infostealer families VIDAR, RISEPRO, REDLINE, RACOON STEALER, LUMMA and METASTEALER, says contractor devices used for personal activity were a frequent source of infection, and prints no ATT&CK ids (Confirmed [42]). The library has software pages for S9050 Vidar, S1240 RedLine Stealer and S1213 Lumma Stealer, bound here only as stealer families Mandiant names; UNC5537 has no ATT&CK object (Demonstrated [92]).

The filings that do not name the platform. Live Nation's 8-K says it identified unauthorized activity in a third-party cloud database environment holding mainly Ticketmaster data on 20 May and that a criminal actor offered alleged user data for sale on 27 May (Confirmed [43]). AT&T's 8-K, filed 12 July, says a threat actor took files from an AT&T workspace on a third-party cloud platform between 14 and 25 April, holding call and text records, without content, of nearly all wireless customers for about May to October 2022 plus 2 January 2023; AT&T learned of it on 19 April, and DOJ determined on 9 May and 5 June that delaying disclosure was warranted (Confirmed [44]). Neither filing names Snowflake (Confirmed [43][44]). Tying them to the UNC5537 campaign rests on reporting outside the opened record and is not made here.

Other SaaS and identity incidents. Cloudflare says it detected a threat actor on its self-hosted Atlassian server on Thanksgiving Day, 23 November 2023, cut off access, brought in CrowdStrike forensics on 26 November, and found no customer data or systems affected; its post is dated 1 February 2024 (Confirmed [1]). On 11 April CISA responded to a compromise of Sisense customer data found by independent researchers and urged customers to reset credentials and secrets (Confirmed [31]). Dropbox says it became aware on 24 April of unauthorized access to the Dropbox Sign production environment and customer information (Confirmed [38]). AA24-046A of 15 February describes an unidentified actor who used a former employee's account to obtain network administrator credentials at a state government organization, authenticated to a VPN and ran LDAP queries against a domain controller; CISA found no movement into Azure (Confirmed [15]). BeyondTrust's SaaS incident, where a third-party zero-day exposed an infrastructure API key, is in Part 2 (Confirmed [81]).

Storm-0501 and the hybrid cloud. On 26 September Microsoft reported that Storm-0501 (G1053) ransomware attacks were expanding from on-premises networks into hybrid cloud environments (Confirmed [63]).

The CSRB on Microsoft. The Cyber Safety Review Board's report on the Summer 2023 Exchange Online intrusion, dated 20 March 2024, found that Storm-0558 succeeded because of a cascade of security failures at

Microsoft, that the intrusion was preventable, and that Microsoft's security culture was inadequate and needed an overhaul (Confirmed [117]). The 2023 events are in the series' 2023 chronicle.

Part 7: ransomware, extortion and the money

Change Healthcare, in one paragraph. The home for this event is the Change Healthcare study. UnitedHealth Group's 8-K under Item 1.05, filed 22 February, says that on 21 February it identified a "suspected nation-state associated" threat actor in some Change Healthcare IT systems and isolated them; that was the initial characterization, and the later attribution to an ALPHV affiliate is in the home study (Confirmed [21]). Change Healthcare's status page reports enterprise-wide connectivity issues and unavailable applications from 02:15 EST on 21 February (Confirmed [22]). On 22 April UnitedHealth said files with PHI or PII found in data sampling could cover a substantial proportion of people in America (Confirmed [23]). ALPHV's ransomware is S1068 BlackCat in ATT&CK (Demonstrated [92]); CISA updated its ALPHV advisory, AA23-353A, on 27 February (Confirmed [97]).

Operation Cronos. On 20 February the NCA, working with the FBI and partners in nine other countries, took control of LockBit's primary administration environment and its public leak site, seized Stealbit infrastructure in three countries, took down 28 affiliate servers and obtained over 1,000 decryption keys; Europol coordinated two arrests in Poland and Ukraine and the freezing of more than 200 cryptocurrency accounts, and the US unsealed indictments against two further Russian nationals (Confirmed [93]). The NCA's announcement adds that it obtained LockBit's source code and identified 194 affiliates (Confirmed [16]). Europol calls LockBit the most deployed ransomware variant in the world; only its page title and description could be read (Confirmed [94]). Treasury designated affiliates Ivan Kondratyev (Bassterlord) and Artur Sungatov, the first action of the joint effort, and states that LockBit was behind the November 2023 attack on ICBC's US broker-dealer (Confirmed [17]). LockBit's longer record, from its start to Cronos and after, is told in the ransomware ecosystem study.

LockBitSupp named. On 7 May the NCA named LockBit's administrator and developer as Dmitry Khoroshev, and said more than 7,000 attacks were built using LockBit's services between June 2022 and February 2024 (Confirmed [18]). Treasury designated Khoroshev the same day as a LockBit leader and the operator of the LockBitSupp moniker; DOJ unsealed an indictment, State announced a reward, and the UK and Australia also designated him (Confirmed [19]). Treasury, citing DOJ, says LockBit targeted over 2,500 victims worldwide and is alleged to have received more than US$500 million in ransom payments, an alleged government figure (Confirmed [19]). On 1 October the third phase of Cronos brought four coordinated arrests in France, the UK and Spain, including a developer and a bulletproof hosting administrator, with twelve countries, Europol and Eurojust taking part; only the page title, description and date could be read (Confirmed [96]). The library's LockBit objects are S1202 LockBit 3.0, in use since June 2022 per the library record, and S1199 LockBit 2.0; the Cronos sources name no version, so the binding to S1202 is this study's (Inferred [92]).

Evil Corp. On 1 October Treasury, with the UK and Australia, designated seven individuals and two entities tied to Evil Corp; DOJ unsealed an indictment against one member over BitPaymer, and the action was timed with the Counter Ransomware Initiative summit of more than 50 countries; Treasury names Aleksandr Ryzhenkov (Guester) as Yakubets' second-in-command (Confirmed [65]). In the library Evil Corp is G0119 Indrik Spider, also known as Manatee Tempest (Demonstrated [92]).

The #StopRansomware advisories. AA24-060A of 29 February describes Phobos as ransomware-as-a-service whose incidents against state, local, tribal and territorial governments have been

reported to MS-ISAC since May 2019, with several million US dollars ransomed (Confirmed [25]). AA24-109A, first released on 18 April, says Akira has hit businesses and critical infrastructure in North America, Europe and Australia since March 2023, with a Linux ESXi variant from April 2023, and cites initial access through VPNs without MFA, known Cisco CVEs, spearphishing, valid credentials, RDP and password spraying; its live page, updated on 13 November 2025, lists later CVEs and a US$244.17 million proceeds figure as of late September 2025, which is not a 2024 fact (Confirmed [36]). AA24-131A of 10 May (revised 8 November) says Black Basta, a ransomware-as-a-service first identified in April 2022, had hit over 500 organizations as of May 2024 across at least 12 of 16 critical infrastructure sectors including healthcare, with double extortion; initial access came through spearphishing, email bombing followed by fake help-desk calls or Teams messages, QakBot, ScreenConnect CVE-2024-1709 and valid credentials (Confirmed [39]). AA24-242A of 29 August says RansomHub, formerly Cyclops and Knight, encrypted and exfiltrated data from at least 210 victims since February 2024 across water, IT, government, healthcare, emergency services, financial and communications sectors, drawing affiliates from LockBit and ALPHV, with initial access from phishing, known CVEs and password spraying (Confirmed [60]). All three of the 2024 advisories on Black Basta, Akira and RansomHub put patching known exploited vulnerabilities first and phishing-resistant MFA next among their mitigations, with offline immutable backups also recommended (Confirmed [60][39][36]). ATT&CK carries S1070 Black Basta, S0650 QakBot, G1024 Akira, S1129 Akira and S1212 RansomHub; Phobos has no ATT&CK object in the library (Demonstrated [92]).

ESXi as the target. Microsoft's report of 29 July on ESXi CVE-2024-37085 ties the flaw to Akira and Black Basta deployments by Storm-0506, Storm-1175, Octo Tempest and Manatee Tempest (Confirmed [109]); see Part 2.

Victims' filings. loanDepot identified unauthorized access and encryption of data and shut down certain systems (8-K filed 8 January) (Confirmed [11]). Synnovis says the cyberattack of 3 June affected all its IT systems and disrupted pathology services (Confirmed [45]). Sonic Automotive's 8-K says CDK Global suspended systems on 19 June after a cybersecurity incident, disrupting its dealer management system (Confirmed [46]). Halliburton learned on 21 August that an unauthorized third party had accessed certain systems and took systems offline (8-K filed 23 August), and a second filing says it believes data was exfiltrated (Confirmed [57][58]). American Water learned of unauthorized activity on 3 October and disconnected certain systems, and believes its water and wastewater operations were not affected (Confirmed [67]). Krispy Kreme was notified of unauthorized activity on 29 November; online ordering in parts of the US was disrupted and a material impact is reasonably likely (8-K filed 11 December) (Confirmed [80]). None of these filings names an actor (Confirmed [11][46][57][67][80]).

Takedowns beyond LockBit. Europol's largest-ever operation against botnets, Operation Endgame, hit the IcedID, SystemBC, Pikabot, Smokeloader, Bumblebee and Trickbot droppers, with four arrests and more than 100 servers taken down; only the page title and description could be read, and one research pass read the dates 27 to 29 May from the page metadata while another could see no date (Confirmed [40]). The library carries S0483 IcedID, S9001 SystemBC, S1145 Pikabot, S0226 Smoke Loader, S1039 Bumblebee and S0266 TrickBot (Demonstrated [92]). On 28 May Treasury designated Yunhe Wang, Jingping Liu and Yanni Zheng over the 911 S5 residential proxy botnet, plus three entities owned by Wang, whom it names as the primary administrator, and tied MaskVPN and DewVPN to the botnet (Confirmed [95]). On 28 October Operation Magnus, led by the Dutch National Police with the FBI and partners, disrupted the RedLine and META infostealers (Confirmed [72]); RedLine is S1240 in the library (Demonstrated [92]).

The money. The FBI's IC3 2024 report counts 3,156 ransomware complaints, calls ransomware the most pervasive threat to critical infrastructure with complaints up 9%, names Akira, LockBit, RansomHub, Fog and Play as the top five variants, and gives an adjusted ransomware loss of US$12,473,156 that leaves out downtime and remediation costs (Confirmed [98]). Chainalysis estimates about US$813.55 million in ransomware payments in 2024, down 35% from US$1.25 billion in 2023, with US$459.8 million in the first half including a record US$75 million to Dark Angels; it says LockBit's second-half payments fell about 79% and that ALPHV exit-scammed (Reported [99]). Coveware says the share of victims who paid fell to an all-time low of 25% in Q4 2024 (Reported [100]).

Part 8: supply chain, outages and trust

XZ Utils, in one paragraph. The home for this event is the XZ Utils study. On 29 March Andres Freund reported on oss-security that the upstream xz repository and the 5.6.0 and 5.6.1 tarballs had been backdoored, leading to SSH server compromise (Confirmed [29]). NVD's record for CVE-2024-3094, published the same day, says the build extracts a prebuilt object file from a disguised test file and modifies liblzma functions, and lists CWE-506 Embedded Malicious Code (Confirmed [113]). CISA's alert told users to downgrade to an uncompromised version such as 5.4.6 and hunt for malicious activity; the CVE is not in KEV (Confirmed [30][3]). Supply-chain attacks through package registries are told in the npm supply-chain study and through model hubs in the Hugging Face study.

polyfill.io. On 26 June Cloudflare said polyfill.io could no longer be trusted, that the service had been used to inject malicious JavaScript into users' browsers, and that it would automatically rewrite links to its own cdnjs mirror (Confirmed [47]). Cloudflare says the domain was sold in February 2024 to Funnull and that multiple reports, which its Page Shield data corroborated, showed the injection; Cloudflare's own action is first-party, while the injection detail is Cloudflare relaying others' reports with its own telemetry (Reported [47]).

CrowdStrike, 19 July. CrowdStrike released a Falcon sensor configuration update for Windows hosts at 04:09 UTC that triggered a logic error and a system crash, and remediated it at 05:27 UTC; the issue was not the result of or related to a cyberattack (Confirmed [50]). Its preliminary post-incident review says the Rapid Response Content in Channel File 291 crashed hosts running sensor 7.11 or later that were online in that window, that a bug in its Content Validator let the faulty content pass, and commits to canary and staggered rollout, more testing, customer control of update timing and independent reviews (Confirmed [138]). CISA attributed the widespread outage to the update, not to malicious activity (Confirmed [51]). Microsoft estimated 8.5 million Windows devices were affected, less than one percent of all Windows machines (Confirmed [52]). It belongs in this chronicle as an outage, not an intrusion (Inferred).

Kaspersky. Commerce BIS's Final Determination ICTS-2021-002, published in the Federal Register on 24 June, barred Kaspersky from new agreements with US persons from 20 July and from the identified transactions, including signature updates and resale, from 29 September (Confirmed [121]).

Part 9: industrial and critical infrastructure

The home for the industrial events of the year is the ICS attacks and advisories study; the earlier industrial record runs back to the Stuxnet study. This Part gives the 2024 sequence in summary.

FrostyGoop. Unit 42 says FrostyGoop used Modbus TCP against a municipal energy company in Ukraine in early 2024, cutting heating to over 600 apartment buildings, and that the malware became publicly known in

July 2024 (Confirmed [54]). ATT&CK records the event as C0041 FrostyGoop Incident, a January 2024 attack on a municipal district heating company, with no group named (Demonstrated [143]).

Fuxnet. Claroty analyzed the Blackjack group's Fuxnet attack on Moscow sensor gateways; Claroty estimated about 500 gateways were affected, while the group claims 2,659 (Confirmed [34] for Claroty's analysis; Reported [34] for the group's claim).

Hacktivists and default passwords. A CISA-led fact sheet of 1 May with the NCSC-UK and partners says pro-Russia hacktivists manipulated small-scale ICS and OT in water, dams, energy and food and agriculture across North America and Europe, using mostly unsophisticated techniques with nuisance effects (Confirmed [118]). On 25 September CISA said exploitation of internet-accessible OT and ICS continues, including in the Water and Wastewater Systems sector, through default credentials, brute force and other unsophisticated methods (Confirmed [119]). The IRGC-CEC defacements of Unitronics PLCs drew sanctions in February (Part 5) (Confirmed [12]).

Utilities and pre-positioning. American Water disconnected certain systems in October and believes its operations were not affected (Confirmed [67]). Volt Typhoon's pre-positioning on IT networks for movement to OT is, in this study's reading, the year's most consequential critical infrastructure finding (Part 3) (Confirmed [13] for the finding; Inferred for the ranking).

Part 10: spyware and AI

Intellexa. On 5 March Treasury sanctioned two individuals and five entities of the Intellexa commercial spyware consortium (Confirmed [26]). The wider market is in the zero-day market study.

State actors and large language models. On 14 February Microsoft and OpenAI published research on state actors' use of large language models; Microsoft said it had not yet observed particularly novel AI-enabled attack techniques (Confirmed [14]). The library's later record of AI-enabled threats is in the AI threats study and the AI Security Reference.

Part 11: the government record

Directives. Emergency Directive 24-01 on Ivanti (19 January) and Emergency Directive 24-02 on Microsoft corporate email (11 April, resets due 30 April) were the year's two emergency directives (Confirmed [4][102][10][116]).

Sanctions and charges. Treasury sanctioned IRGC-CEC officials (2 February) and IRGC-CEC fronts (23 April), two LockBit affiliates (20 February), the Intellexa consortium (5 March), Wuhan XRZ and two APT31-linked nationals (25 March), Khoroshev (7 May), the 911 S5 administrators (28 May), two CARR members (19 July), seven Iranian election interferers (27 September), Evil Corp (1 October) and Sichuan Silence (10 December) (Confirmed [12][37][17][26][28][19][95][53][64][65][79]). The UK matched the APT31, Khoroshev and Evil Corp actions (Confirmed [27][18][65]).

Law enforcement. Operation Cronos (20 February, with a third phase on 1 October), Operation Endgame (May) and Operation Magnus (28 October) are in Part 7 (Confirmed [93][96][40][72]).

Courts and boards. In SEC v. SolarWinds Corp., 1:23-cv-09518 (S.D.N.Y.), Judge Engelmayer's Opinion and Order of 18 July granted in part and denied in part the defendants' motion to dismiss (Confirmed [122]); the

incident is told in the SolarWinds study. The CSRB's Storm-0558 report is in Part 6 (Confirmed [117]).

US executive action and rules. Executive Order 14117, signed 28 February and published 1 March, restricts countries of concern from accessing Americans' bulk sensitive personal data and US government-related data (Confirmed [123]). CISA's CIRCIA proposed rule (6 CFR 226) was published on 4 April with comments due 3 June, later extended (Confirmed [124]). NSM-22 of 30 April makes DHS the coordinator of cross-sector risk management with Sector Risk Management Agencies as day-to-day federal interfaces (Confirmed [125]). CISA's Secure by Design pledge launched on 8 May with 68 software manufacturers and seven one-year goals: MFA, default passwords, vulnerability classes, patch uptake, a disclosure policy, accurate CWE and CPE in CVE records, and evidence of intrusions (Confirmed [139]). The Kaspersky determination is in Part 8 (Confirmed [121]).

Standards. NIST released Cybersecurity Framework 2.0 on 26 February, the first major update since 2014, with more emphasis on governance and supply chains (Confirmed [126]). On 13 August NIST released the first three finalized post-quantum standards, FIPS 203, 204 and 205; ML-KEM is the renamed CRYSTALS-Kyber, and FIPS 204 uses CRYSTALS-Dilithium (Confirmed [127]).

Abroad. The UK's PSTI regime came into force on 29 April and bans weak, easily guessable default passwords on consumer connected products; the UK says it is the first country to do so (Confirmed [128]). EU Member States had until 17 October to transpose NIS2, Directive (EU) 2022/2555, and NIS1 was repealed from 18 October (Confirmed [129]). Australia's Cyber Security Act 2024 (No. 98, 2024) is dated 29 November and its Part 3 sets ransomware payment reporting obligations (Confirmed [130]). The UN General Assembly adopted the UN Convention against Cybercrime by consensus in resolution 79/243 on 24 December; it opened for signature in Hanoi on 25 October 2025 (Confirmed [131]).

Part 12: the defender view

Patch the edge on the KEV clock, then distrust the appliance. AA24-060B asks defenders to limit outbound traffic from SSL VPN appliances, patch within 24 to 48 hours, reset credentials stored on the appliance and weigh the risk of keeping it in service, because the vendor's integrity tool missed compromise and persistence survived a factory reset in CISA's lab (Confirmed [5]). AA24-038A asks that edge appliances and KEV entries be patched first and that no credentials be stored on edge devices (Confirmed [13]). AA24-317A adds checking for compromise before patching (Confirmed [74]).

MFA everywhere, including where nobody looks. The account Midnight Blizzard sprayed was a legacy test account without MFA; the UNC5537 accounts had no MFA and stale credentials; Akira came through VPNs without MFA (Confirmed [132][42][36]). Each of the three 2024 #StopRansomware advisories on Black Basta, Akira and RansomHub puts phishing-resistant MFA second only to patching (Confirmed [39][36][60]).

Govern the cloud's non-human identities. Microsoft's guidance asks defenders to audit privileges of identities, service principals and applications, review apps holding EWS.AccessAsUser.All or full_access_as_app, use RBAC for applications, App governance and Entra ID Protection risk-based MFA, and hunt with audit logs because IP indicators are unreliable (Confirmed [132]).

Treat infostealer exposure as a breach. Mandiant recommends universal MFA, credential rotation, network allow lists and control of contractor devices (Confirmed [42]).

Log off the device and alert on configuration change. The telecom guidance asks for a central configuration store with change alerting, flow monitoring, secure centralized logging, no internet-exposed management, out-of-band management, disabled insecure protocols, phishing-resistant MFA for router administration and tracking of end-of-life equipment (Confirmed [77]).

Plan for your own vendor's failure. CrowdStrike's commitments after 19 July are canary and staggered rollout and customer control of update timing (Confirmed [138]). Backups that are offline and immutable remain the ransomware advisories' recovery control (Confirmed [60]).

Hunting cues from the record. At the advisory level, and without commands. Each cue is this study's reading of a behavior the sources describe (behaviors Confirmed; cues Inferred):

- Edge appliances: web shells and unexpected files on VPN gateways and firewalls, configuration exports from firewalls and management planes, and outbound connections from SSL VPN appliances (Confirmed [5][32][69]).
- Cloud identity: new OAuth applications or users that consent to them, applications granted full mailbox access roles, and mail read through Exchange Web Services by unexpected applications (Confirmed [132]).
- Credentials: sign-ins to cloud data platforms from accounts with no MFA, logins with credentials seen in infostealer logs, and sprays against service and dormant accounts (Confirmed [42][87]).
- Living off the land: domain controller credential extraction and event log clearing outside change windows, and proxying through SOHO devices (Confirmed [13]).
- Ransomware precursors: remote access tools appearing where they are not used, email bombing followed by help-desk calls or Teams messages, and attempts to disable security tools (Confirmed [39][60]).

Exposure management. See the library's Vulnerability Prioritization Reference, Edge Device Security Reference, Identity Security Reference and Ransomware Defense Reference.

Part 13: MITRE mappings

This Part binds the verified 2024 record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND, with every id checked against the library's data files (`data/attack/technique_profiles.jsonl`, `data/attack/superseded_by.jsonl`, `data/attack/groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `campaign_profiles.jsonl`, `data/attack/technique_to_d3fend.jsonl`, `data/attack/d3fend_countermeasures.jsonl`, `data/weaknesses/cwe.jsonl` and `data/weaknesses/capec.jsonl`) and the generated pages under `mitre/` on 11 November 2026 (Demonstrated [146][140][92][143][141][142]). Tactic names follow ATT&CK v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment.

Each row carries a basis. **Source** means an opened advisory or the ATT&CK record prints the ATT&CK id itself. **Behavior** means the source describes the behavior and this study assigns the id (the behavior is Confirmed; the mapping is this study's reading). **Inferred** means the id rests on this study's reading of a source that lists no ids, for an actor with no ATT&CK object (UNC5537). The advisories' printed ids were resolved against v20.0: T1562.001 is revoked into T1685 Disable or Modify Tools, T1562.004 into T1686 Disable or Modify System Firewall, and T1070.001 into T1685.005 Clear Windows Event Logs (Confirmed [140]). Rows marked "live table" come from AA24-109A's page as revised on 13 November 2025; they are

kept because the 2024 release describes the same entry behavior, but they are not dated to 2024 on the revised table's authority alone (Confirmed [36]; Inferred for the decision).

ATT&CK Enterprise techniques

Id	Name	Tactic (v20.0)	Where it appears in the 2024 record	Basis	Source
T1595.001	Scanning IP Blocks	Reconnaissance	AA24-249A table (Unit 29155, 5 Sep)	Source	[61]
T1595.002	Vulnerability Scanning	Reconnaissance	AA24-249A table	Source	[61]
T1583.003	Virtual Private Server	Resource Development	AA24-038A table (Volt Typhoon, 7 Feb)	Source	[13]
T1584.005	Botnet	Resource Development	AA24-038A, KV Botnet on end-of-life SOHO routers	Source	[13]
T1584.008	Network Devices	Resource Development	AA24-190A, SOHO devices as last-hop redirectors (APT40, 8 Jul)	Source	[49]
T1587.004	Exploits	Resource Development	AA24-038A table	Source	[13]
T1588.005	Exploits	Resource Development	AA24-038A and AA24-242A tables (RansomHub, 29 Aug)	Source	[13][60]
T1190	Exploit Public-Facing Application	Initial Access	AA24-038A, AA24-060B, AA24-131A, AA24-242A and AA24-249A tables; AA24-109A live table; ATT&CK C0041; behavior in Ivanti (Jan), PAN-OS (Apr), FortiManager (Jun to Oct), ScreenConnect (Feb) and Andariel's web server exploitation (AA24-207A)	Source; Behavior	[13][5][39][36][60][61][143][2][32][69][55]
T1133	External Remote Services	Persistence, Initial Access	AA24-038A table; AA24-109A live table (VPN without MFA); VPN logon with a former employee's credentials (AA24-046A) as Behavior	Source; Behavior	[13][36][15]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA24-038A, AA24-060B, AA24-131A and AA24-249A tables; AA24-109A live table; the former employee's account (AA24-046A) as Behavior	Source; Behavior	[13][5][39][36][61][15]
T1078.004	Cloud Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA24-038A table; Microsoft's legacy test tenant account (Behavior); UNC5537's Snowflake accounts (Inferred)	Source; Behavior; Inferred	[13][132][42]
T1566	Phishing	Initial Access	AA24-131A and AA24-242A tables	Source	[39][60]
T1566.001	Spearphishing Attachment	Initial Access	AA24-109A live table; the RDP attachment campaign (CISA, 31 Oct) as Behavior	Source; Behavior	[36][73]

Id	Name	Tactic (v20.0)	Where it appears in the 2024 record	Basis	Source
T1566.002	Spearphishing Link	Initial Access	AA24-109A live table; APT42's credential phishing (Google TAG, 14 Aug) as Behavior	Source; Behavior	[36][89]
T1566.004	Spearphishing Voice	Initial Access	AA24-131A table (fake help-desk calls, Black Basta, 10 May)	Source	[39]
T1195.002	Compromise Software Supply Chain	Initial Access	XZ Utils 5.6.0 and 5.6.1 (29 Mar)	Behavior	[29][113]
T1059.001	PowerShell	Execution	AA24-038A, AA24-060B, AA24-131A and AA24-242A tables	Source	[13][5][39][60]
T1047	Windows Management Instrumentation	Execution	AA24-038A and AA24-242A tables	Source	[13][60]
T1203	Exploitation for Client Execution	Execution	AA24-060B table (Ivanti, 29 Feb)	Source	[5]
T1204	User Execution	Execution	AA24-131A table	Source	[39]
T1505.003	Web Shell	Persistence	AA24-060B, AA24-190A and AA24-249A tables; ATT&CK C0041; Andariel's web shells (AA24-207A) and Volexity's Ivanti finding as Behavior	Source; Behavior	[5][49][61][143][55][2]
T1098	Account Manipulation	Persistence, Privilege Escalation	AA24-242A table	Source	[60]
T1098.003	Additional Cloud Roles	Persistence, Privilege Escalation	Midnight Blizzard grants the full_access_as_app role (Microsoft, 25 Jan)	Behavior	[132]
T1136	Create Account	Persistence	AA24-242A table	Source	[60]
T1136.003	Cloud Account	Persistence	Midnight Blizzard creates a user to consent to its OAuth applications	Behavior	[132]
T1068	Exploitation for Privilege Escalation	Privilege Escalation	AA24-038A and AA24-131A tables; AA24-109A live table	Source	[13][39][36]
T1006	Direct Volume Access	Stealth	AA24-038A table	Source	[13]
T1218	System Binary Proxy Execution	Stealth	AA24-038A table	Source	[13]
T1036	Masquerading	Stealth	AA24-131A and AA24-242A tables	Source	[39][60]
T1070	Indicator Removal	Stealth	AA24-242A table	Source	[60]

Id	Name	Tactic (v20.0)	Where it appears in the 2024 record	Basis	Source
T1685	Disable or Modify Tools	Defense Impairment	Printed as T1562.001 in AA24-131A, AA24-242A and the AA24-109A live table	Source	[39][60][36][140]
T1685.005	Clear Windows Event Logs	Defense Impairment	Printed as T1070.001 in AA24-038A	Source	[13][140]
T1686	Disable or Modify System Firewall	Defense Impairment	Printed as T1562.004 in the AA24-109A live table	Source	[36][140]
T1689	Downgrade Attack	Defense Impairment	ATT&CK C0041 FrostyGoop Incident (Jan)	Source	[143]
T1003	OS Credential Dumping	Credential Access	AA24-242A table	Source	[60]
T1003.001	LSASS Memory	Credential Access	AA24-038A, AA24-249A and AA24-109A live tables	Source	[13][61][36]
T1003.002	Security Account Manager	Credential Access	ATT&CK C0041	Source	[143]
T1003.003	NTDS	Credential Access	AA24-038A table and AA24-109A live table	Source	[13][36]
T1110	Brute Force	Credential Access	AA24-057A (SVR, 26 Feb)	Source	[87][24]
T1110.003	Password Spraying	Credential Access	AA24-242A and AA24-249A tables; AA24-109A live table; Midnight Blizzard at Microsoft (Nov 2023 to Jan), Iranian spraying (AA24-290A) and Nearest Neighbor (Volexity, 22 Nov) as Behavior	Source; Behavior	[36][60][61][7][132][68][88]
T1528	Steal Application Access Token	Credential Access	AA24-057A (system-issued tokens); Midnight Blizzard's legacy OAuth application as Behavior	Source; Behavior	[87][132]
T1552.004	Private Keys	Credential Access	AA24-038A table	Source	[13]
T1621	Multi-Factor Authentication Request Generation	Credential Access	MFA push bombing by Iranian actors (AA24-290A, 16 Oct)	Behavior	[68]
T1654	Log Enumeration	Discovery	AA24-038A table	Source	[13]
T1018	Remote System Discovery	Discovery	AA24-242A table	Source	[60]
T1046	Network Service Discovery	Discovery	AA24-242A table	Source	[60]
T1021.001	Remote Desktop Protocol	Lateral Movement	AA24-038A and AA24-242A tables; AA24-109A live table	Source	[13][60][36]
T1210	Exploitation of Remote Services	Lateral Movement	AA24-242A table	Source	[60]

Id	Name	Tactic (v20.0)	Where it appears in the 2024 record	Basis	Source
T1550.002	Pass the Hash	Lateral Movement	AA24-249A table	Source	[61]
T1074	Data Staged	Collection	AA24-038A table; UNC5537's staging (Inferred)	Source; Inferred	[13][42]
T1114.002	Remote Email Collection	Collection	Midnight Blizzard reads Microsoft corporate mail through EWS	Behavior	[7][132]
T1213.003	Code Repositories	Collection	Midnight Blizzard reaches some Microsoft source code repositories (8 Mar)	Behavior	[8][115]
T1213.006	Databases	Collection	UNC5537 takes data from Snowflake customer instances	Inferred	[42]
T1071	Application Layer Protocol	Command and Control	ATT&CK C0041	Source	[143]
T1090.001	Internal Proxy	Command and Control	AA24-038A table	Source	[13]
T1090.002	External Proxy	Command and Control	Midnight Blizzard's residential proxies	Behavior	[132]
T1090.003	Multi-hop Proxy	Command and Control	AA24-038A and AA24-249A tables; AA24-109A live table	Source	[13][61][36]
T1219	Remote Access Tools	Command and Control	AA24-242A table; AA24-109A live table	Source	[60][36]
T1572	Protocol Tunneling	Command and Control	AA24-249A table; AA24-109A live table	Source	[61][36]
T1048	Exfiltration Over Alternative Protocol	Exfiltration	AA24-038A table	Source	[13]
T1048.002	Exfiltration Over Asymmetric Encrypted Non-C2 Protocol	Exfiltration	AA24-242A table	Source	[60]
T1048.003	Exfiltration Over Unencrypted Non-C2 Protocol	Exfiltration	AA24-242A table	Source	[60]
T1537	Transfer Data to Cloud Account	Exfiltration	AA24-242A table; AA24-109A live table	Source	[60][36]
T1567.002	Exfiltration to Cloud Storage	Exfiltration	AA24-249A table; AA24-109A live table	Source	[61][36]
T1485	Data Destruction	Impact	AA24-249A table (WhisperGate)	Source	[61]
T1486	Data Encrypted for Impact	Impact	AA24-131A and AA24-242A tables; AA24-109A live table	Source	[39][60][36]
T1490	Inhibit System Recovery	Impact	AA24-131A and AA24-242A tables; AA24-109A live table	Source	[39][60][36]

Id	Name	Tactic (v20.0)	Where it appears in the 2024 record	Basis	Source
T1657	Financial Theft	Impact	AA24-109A live table	Source	[36]

Ids the record mentions but this study leaves out. AA24-109A's live tables print T1604, a Mobile id that is absent from the library's Enterprise data, so it is not in the table or the layer (Confirmed [36]; Demonstrated [146]). AA24-038A's appendix tables were read only in part; ids beyond those listed above are not bound (Confirmed [13]). The research notes that some advisory tables misfile tactics (AA24-038A puts T1003.001 under Execution, AA24-242A puts T1021.001 under Privilege Escalation); this study shows every id under the tactics the library's v20.0 data gives it (Inferred for the reading; Demonstrated [146]). Microsoft's Midnight Blizzard guidance and Mandiant's UNC5537 report print no ATT&CK ids, which is why their rows are Behavior or Inferred (Confirmed [132][42]).

ATT&CK for ICS techniques

No ATT&CK for ICS technique is bound here; the library's ICS data carries FrostyGoop (S1165) and CyberAv3ngers (G1027) without generated pages, and the ICS rows for FrostyGoop, Fuxnet and the Unitronics defacements are bound in the home study (Demonstrated [92][143]). That home study is the ICS attacks and advisories study. The Enterprise rows from the ATT&CK C0041 campaign record (T1190, T1505.003, T1689, T1003.002 and T1071) are in the table above (Demonstrated [143]).

ATT&CK groups, software and campaigns

Object	Id and library page	Tie to the 2024 record	Source
Volt Typhoon	G1017	AA24-038A (7 Feb)	[13]
KV Botnet Activity	C0035	The KV Botnet malware AA24-038A names; the campaign binding is this study's (Inferred)	[13][143]
Versa Director Zero Day Exploitation	C0039	A 2024 Volt Typhoon campaign in ATT&CK; its primary was not opened, so it is named, not bound to an event	[143]
Salt Typhoon	G1045	The telecom campaign (13 Nov, 3 to 4 Dec); the 2024 statements do not use the name, so the binding is Inferred	[75][77][83]
ZIRCONIUM	G0128	APT31 alias; UK and Treasury actions (25 Mar)	[27][28][92]
Leviathan	G0065	APT40 alias; AA24-190A (8 Jul)	[49][92]
Velvet Ant	G1047	Sygnia (3 Jun)	[85]
UNC3886	G1048	Mandiant (18 Jun)	[86]
Cutting Edge	C0029	Ivanti Connect Secure exploitation (Dec 2023 to Feb 2024)	[2][84][143]
ArcaneDoor	C0046	Cisco ASA campaign (Talos, Apr)	[91]
Line Runner	S1188	ArcaneDoor backdoor	[91]
Line Dancer	S1186	ArcaneDoor backdoor	[91]
Operation MidnightEclipse	C0048	PAN-OS CVE-2024-3400 (Mar to Apr)	[32][143]
UPSTYLE	S1164	Volexity's PAN-OS backdoor	[32]
APT29	G0016	Midnight Blizzard alias; Microsoft and HPE mail, ED 24-02, AA24-057A, the RDP attachment campaign	[7][6][10][87][73][92]
Sandworm Team	G0034	APT44 alias; Mandiant (17 Apr)	[35][92]
Ember Bear	G1003	GRU Unit 29155; AA24-249A (5 Sep)	[61]
WhisperGate	S0689	Deployed from 13 Jan 2022 (AA24-249A)	[61]
APT28	G0007	GruesomeLarch; Nearest Neighbor (22 Nov)	[88]
APT28 Nearest Neighbor Campaign	C0051	The 2022 intrusion reported in 2024	[88][143]
Star Blizzard	G1033	Domain seizure (3 Oct)	[66]
Turla	G0010	Secret Blizzard alias; Storm-0156 infrastructure (4 Dec)	[78][92]

Object	Id and library page	Tie to the 2024 record	Source
Fox Kitten	G0117	Pioneer Kitten and Lemon Sandstorm aliases; AA24-241A (28 Aug)	[59][92]
APT42	G1044	Election targeting (Google TAG, 14 Aug)	[89]
Andariel	G0138	Onyx Sleet alias; AA24-207A (25 Jul)	[55][92]
Moonstone Sleet	G1036	Microsoft (28 May); FakePenny ransomware	[90]
Indrik Spider	G0119	Evil Corp and Manatee Tempest aliases; designations (1 Oct); ESXi CVE-2024-37085 (29 Jul)	[65][109][92]
Scattered Spider	G1015	Octo Tempest alias; ESXi CVE-2024-37085 (29 Jul)	[109][92]
Storm-0501	G1053	Hybrid cloud ransomware (26 Sep)	[63]
Akira	G1024	AA24-109A (18 Apr); IC3's top variant	[36][98]
Akira	S1129	The ransomware software object; AA24-109A	[36]
Black Basta	S1070	AA24-131A (10 May)	[39]
QakBot	S0650	Black Basta initial access (AA24-131A)	[39]
RansomHub	S1212	AA24-242A (29 Aug)	[60]
BlackCat	S1068	ALPHV alias; AA23-353A update (27 Feb); AA24-241A; home study for Change Healthcare	[97][59][92]
LockBit 3.0	S1202	Operation Cronos and Khoroshev (version binding Inferred)	[93][19][92]
LockBit 2.0	S1199	LockBit's earlier variant; no 2024 source names it (version binding Inferred)	[92]
IcedID	S0483	Operation Endgame (May)	[40]
SystemBC	S9001	Operation Endgame	[40]
Pikabot	S1145	Operation Endgame	[40]
Smoke Loader	S0226	Operation Endgame	[40]
Bumblebee	S1039	Operation Endgame	[40]
TrickBot	S0266	Operation Endgame (per one reading of the Europol page)	[40]
RedLine Stealer	S1240	Operation Magnus (28 Oct); named by Mandiant for UNC5537	[72][42]
Lumma Stealer	S1213	Named by Mandiant for UNC5537	[42]
Vidar	S9050	Named by Mandiant for UNC5537	[42]
FrostyGoop Incident	C0041	Ukrainian district heating (Jan)	[54][143]

That is 47 objects with library pages (counting Smoke Loader). The three campaigns C0059 Salesforce Data Exfiltration, C0060 Operation AkaiRyu and C0061 Operation Digital Eye are also dated to 2024 by the library, but like C0039 above their primaries were not opened, so they are named and not bound (Demonstrated [143]). No ATT&CK object in the library covers Flax Typhoon, UNC5537, UNC5820, UTA0178, UTA0218, UAT4356, APT45, Cyber Army of Russia Reborn, Integrity Technology Group, Storm-0156, Blackjack, Phobos, Fog or Dark Angels, and CyberAv3ngers is G1027 in the library's ICS data but has no generated page, so it stays unlinked (Demonstrated [92]). The Salt Typhoon binding rests on the ATT&CK record, not the 2024 statements (Inferred [83]).

CWE and CAPEC

Weakness	CVEs in this record	CAPEC in the library	Source
CWE-287 Improper Authentication	CVE-2023-46805 (Ivanti; NVD); CVE-2024-37085 (ESXi, with CWE-305)	CAPEC-115 Authentication Bypass, one of ten the library relates; the pick is this study's (Inferred)	[144][109][142]
CWE-77 Improper Neutralization of Special Elements used in a Command	CVE-2024-21887 (Ivanti); CVE-2024-3400 (PAN-OS; NVD and CNA); CVE-2024-55956 (Cleo)	CAPEC-248 Command Injection, one of eight the library relates; the pick is this study's (Inferred)	[144][134][112][142]
CWE-918 Server-Side Request Forgery	CVE-2024-21893 (Ivanti SAML)	CAPEC-664 Server Side Request Forgery	[145][142]
CWE-288 Authentication Bypass Using an Alternate Path or Channel	CVE-2024-1709 (ScreenConnect; CNA); CVE-2024-27198 (TeamCity)	The library relates CAPEC-127 and CAPEC-665; neither fits these flaws, so none is bound	[133][104][142]
CWE-306 Missing Authentication for Critical Functionality	CVE-2024-47575 (FortiManager); CVE-2024-0012 (PAN-OS)	The library relates CAPEC-12, 36, 62, 166 and 216; none is a clear fit, so none is bound	[70][135][111][142]
CWE-78 Improper Neutralization of Special Elements used in an OS Command	CVE-2024-4577 (PHP-CGI); CVE-2024-9474 (PAN-OS)	CAPEC-88 OS Command Injection, one of five the library relates; the pick is this study's (Inferred)	[108][111][142]
CWE-20 Improper Input Validation	CVE-2024-3400 (CNA)	Many related CAPEC in the library; none is a clear fit, so none is bound	[134][142]
CWE-506 Embedded Malicious Code	CVE-2024-3094 (XZ Utils; NVD and the CNA)	CAPEC-442 Infected Software, which the library relates to CWE-506 and pairs with T1195.002; CAPEC-538 Open-Source Library Manipulation, which the library pairs with T1195.001 (Inferred fit)	[113][142][141]
CWE-362 and CWE-364 Concurrent Execution using Shared Resource with Improper Synchronization; Signal Handler Race Condition	CVE-2024-6387 (regreSSHion; NVD CWE-362, CNA CWE-364)	CAPEC-26 Leveraging Race Conditions, related to CWE-362; the library relates none to CWE-364	[137][142]
CWE-200 Exposure of Sensitive Information to an Unauthorized Actor	CVE-2024-24919 (Check Point; CNA)	Many related CAPEC; none bound	[136][142]
CWE-502 Deserialization of Untrusted Data	CVE-2024-40711 (Veeam)	CAPEC-586 Object Injection	[110][142]

Weakness	CVEs in this record	CAPEC in the library	Source
CWE-89 Improper Neutralization of Special Elements used in an SQL Command	CVE-2023-48788 (FortiClient EMS)	CAPEC-66 SQL Injection, one of six the library relates	[105][142]
CWE-94 Improper Control of Generation of Code	CVE-2024-20359 (Cisco ASA); CVE-2024-4040 (CrushFTP, with CWE-1336)	CAPEC-242 Code Injection, one of three the library relates	[91][106][142]
CWE-787 Out-of-bounds Write	CVE-2024-21762 (FortiOS)	None in the library	[103][142]
CWE-835 Loop with Unreachable Exit Condition	CVE-2024-20353 (Cisco ASA)	None in the library	[91][142]
CWE-434 Unrestricted Upload of File with Dangerous Type	CVE-2024-50623 (Cleo)	The library relates CAPEC-1; it is not a clear fit, so none is bound	[112][142]

The library pairs CAPEC with many of this study's techniques; the three pairings below bear on the year's central credential behavior (Demonstrated [146][142]):

Technique	CAPEC in the library	2024 behavior
T1110.003 Password Spraying	CAPEC-565 Password Spraying	Midnight Blizzard, AA24-057A, AA24-109A, AA24-242A, AA24-249A, AA24-290A
T1078 Valid Accounts	CAPEC-560 Use of Known Domain Credentials	The former employee's account (AA24-046A); the 2024 ransomware advisories
T1133 External Remote Services, T1114.002 Remote Email Collection	CAPEC-555 Remote Services with Stolen Credentials	Akira's VPN access; Midnight Blizzard's mail access

The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	The library's mappings to this study's techniques (technique_to_d3fend.json)	2024 guidance it matches	Source
Multi-factor Authentication (D3-MFA)	T1003.003, T1110.003, T1528	Phishing-resistant MFA in AA24-038A and the three #StopRansomware advisories; the missing MFA at Microsoft and in UNC5537's accounts	[141][13][39][36][60][132][42]
Credential Rotation (D3-CRO)	T1003.003, T1110.003, T1528	Mandiant's rotation advice; Sisense secret resets	[141][42][31]
Credential Revocation (D3-CR)	T1003.003, T1110.003, T1528	ED 24-02's credential resets; AA24-060B's reset of credentials stored on appliances	[141][10][5]
Credential Hardening (D3-CH)	T1003.003, T1110.003, T1528	No credentials stored on edge devices (AA24-038A)	[141][13]
Connection Attempt Analysis (D3-CAA)	T1047, T1110.003	Detecting low-volume sprays from residential proxies (pairing Inferred)	[141][132]
Strong Password Policy (D3-SPP)	T1110.003	Password spraying of service and dormant accounts (AA24-057A)	[141][87]
Access Modeling (D3-AM)	T1078, T1078.004, T1098, T1098.003, T1136, T1136.003	Auditing privileges of identities, service principals and apps (Microsoft)	[141][132]
User Account Permissions (D3-UAP)	T1078, T1078.004, T1098, T1098.003, T1136, T1136.003	Least privilege (AA24-038A); RBAC for applications (Microsoft)	[141][13][132]
Token Binding (D3-TB)	T1528	System-issued tokens abused by the SVR (pairing Inferred)	[141][87]
Inbound Traffic Filtering (D3-ITF)	T1190	No internet-exposed management interfaces (telecom guidance)	[141][77]
Network Traffic Filtering (D3-NTF)	T1190, T1021.001, T1047, T1090.002, T1090.003, T1110.003, T1219, T1567.002, T1572	Network allow lists for Snowflake instances (Mandiant); limited RDP and OT segmentation (AA24-038A)	[141][42][13]
Outbound Traffic Filtering (D3-OTF)	T1090.002, T1090.003, T1219, T1567.002, T1572	Limiting outbound traffic from SSL VPN appliances (AA24-060B)	[141][5]

Countermeasure	The library's mappings to this study's techniques (`technique_to_d3fend.json`)	2024 guidance it matches	Source
User Geolocation Logon Pattern Analysis (D3-UGLPA)	T1190, T1021.001, T1047, T1090.002, T1090.003, T1110.003, T1219, T1567.002, T1572	Microsoft's caution that IP indicators are unreliable against residential proxies (pairing Inferred)	[141][132]
Remote Terminal Session Detection (D3-RTSD)	T1021.001, T1047, T1110.003, T1190, T1219, T1572	Remote access tools and RDP in the ransomware advisories (pairing Inferred)	[141][60][36]
Session Termination (D3-ST)	T1021.001, T1133	Ending VPN sessions held with a former employee's credentials (pairing Inferred)	[141][15]
File Integrity Monitoring (D3-FIM)	T1486, T1505.003	Web shell detection on edge appliances, with AA24-060B's warning that the vendor's own checker missed them	[141][5]
Executable Allowlisting (D3-EAL)	T1047, T1505.003	Limiting what runs on servers that host web shells (pairing Inferred)	[141][49]
Restore File (D3-RF)	T1486, T1505.003	Offline immutable backups (AA24-242A, AA24-131A, AA24-109A)	[141][60][39][36]
Software Update (D3-SU)	T1195.002, T1490	KEV-first patching in AA24-038A, AA24-317A and the three #StopRansomware advisories; XZ downgrade to 5.4.6	[141][13][74][39][36][60][30]
Asset Vulnerability Enumeration (D3-AVE)	T1195.002, T1490	Knowing which edge appliances and end-of-life devices are exposed (AA24-038A, AA24-190A)	[141][13][49]

Gaps in the library's map: it binds no D3FEND countermeasure to T1566.004 Spearphishing Voice or to T1530, though the Black Basta fake help-desk calls are exactly the case the help desk needs a control for; it binds Multi-factor Authentication to T1528 and T1110.003 but not to T1078.004 Cloud Accounts, the technique where its absence mattered most in 2024 (Demonstrated [141]; Inferred for the reading). The library's D3FEND Reference covers the countermeasures.

Navigator layer

The study's Enterprise techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/chronicle-2024.json, listed on the Navigator layers page. Open it in the ATT&CK Navigator. It is pinned to ATT&CK v20 and is checked against the library's technique profiles by the repository's `scripts/validate_navigator.py` gate. Scores show the basis, not severity: 100 where an opened source prints the id, 70 where the source describes the behavior and this study assigns the id, and 40 for an Inferred mapping. Each entry's comment names the event, the date and the source numbers above, and each technique is shown under every tactic it has in v20.0. There is no ICS layer, because no ICS technique is bound here.

Cross-cutting themes

- **The edge was the front door again, and its self-checks failed (Inferred).** Ivanti, PAN-OS, Cisco ASA, FortiManager and ScreenConnect were exploited at or before disclosure, and AA24-060B found the vendor's integrity tool missed compromise (Confirmed [2][32][91][69][20][5]). See Edge Device Security.
- **Identity was the perimeter (Inferred).** Microsoft's corporate mail, the Snowflake customer tenants and Akira's VPN entries all turned on a credential without MFA, and the Change Healthcare home study tells its own credential story (Confirmed [132][42][36]). See Cloud Attacks and Identity Security.
- **Living off the land made dwell time long (Inferred).** Volt Typhoon's five-year footholds and the telecom campaign put detection weight on behavior, logging and configuration integrity rather than malware signatures (Confirmed [13][77]).
- **Ransomware ran as an affiliate economy that sold and bought access (Inferred).** Black Basta, Akira and RansomHub share the same entry set, RansomHub drew affiliates from LockBit and ALPHV, and Iranian actors sold access for a cut (Confirmed [39][36][60][59]). See Ransomware Defense and the ransomware ecosystem study.
- **Trust in maintainers and vendors was tested from three sides (Inferred).** Upstream XZ Utils releases were backdoored (Confirmed [29]), a domain sold in February 2024 was reported to serve malicious JavaScript through polyfill.io (Reported [47]), and a security vendor's own update crashed an estimated 8.5 million Windows devices (Confirmed [50][52]). See Supply Chain Security.
- **Enforcement went after infrastructure and people, not only binaries (Inferred).** Cronos, Endgame and Magnus took servers and keys, and sanctions named leaders and front companies (Confirmed [93][40][72][19][28][79]). See Threat Actors and Malware Families.

What is overstated and what is understated

- **Overstated: "Snowflake was breached."** Mandiant found no evidence of a breach of Snowflake's enterprise environment; the opened record describes customer accounts accessed with infostealer credentials and no MFA, and AT&T's and Live Nation's filings say only "a third-party cloud" platform or database (Confirmed [42][44][43]; Inferred for the reading).
- **Overstated: the CrowdStrike outage as an attack.** CrowdStrike, CISA and Microsoft all describe a faulty update, not an intrusion (Confirmed [50][51][52]).
- **Overstated: firm national labels for some campaigns.** Mandiant declined to assess UNC5221's origin while Volexity "has reason to believe" UTA0178 is Chinese; Talos names no state for ArcaneDoor; the

Electoral Commission compromise is attributed to "a Chinese state-affiliated entity", not to APT31; and the 2024 government statements on the telecom campaign do not use the name Salt Typhoon (Confirmed [84][2][91][27][75][77]).

- **Overstated: the Change Healthcare actor as a nation-state.** The first 8-K said "suspected nation-state associated"; the crime attribution came later and lives in the home study (Confirmed [21]).
- **Overstated: the precision of advisory technique tables.** Tables misfile tactics, AA24-109A prints a Mobile id in an Enterprise table, and revised live pages are not 2024 snapshots (Confirmed [36][39]; Demonstrated [146]; Inferred for the reading).
- **Overstated: dollar and victim figures read as totals.** LockBit's US$500 million is an alleged DOJ figure; "over 500" Black Basta victims, "at least 210" for RansomHub and "about 165 notified" for UNC5537 are lower bounds or notification counts; Akira's US$244.17 million is a 2025 figure (Confirmed [19][39][60][42][36]).
- **Understated: intrusions nobody detected.** Five-year dwell for Volt Typhoon and an integrity checker that missed compromise make the public record a floor (Confirmed [13][5]; Inferred for the reading).
- **Understated: ransomware losses.** IC3's US$12.47 million adjusted loss excludes downtime and remediation and covers only complaints to IC3, against Chainalysis's estimate of about US$813.55 million in payments, itself an on-chain lower bound (Confirmed [98]; Reported [99]; Inferred for the comparison).
- **Understated: routine OT tampering.** Hacktivist manipulation of water and other small ICS was common enough to draw a May fact sheet and a September alert, and the Unitronics defacements drew sanctions despite no disruption of critical services (Confirmed [118][119][12]).
- **Understated: the density of the government record.** Two emergency directives, a dozen sanctions actions, three named police operations, a product ban and binding standards in three jurisdictions fell in one year (Confirmed, Part 11; Inferred for the reading).
- **Understated: KEV's ransomware flag as history.** The flag is current, not the state at listing, so counts drawn from it can shift as CISA updates entries (Confirmed [3]; Inferred for the caution).

Discrepancies in the record

- **Ivanti attribution.** Volexity "has reason to believe" UTA0178 is a Chinese nation-state-level actor; Mandiant, at publication, did not have enough data to assess UNC5221's origin (Confirmed [2][84]).
- **LockBit's scale.** The NCA counts more than 7,000 attacks built with LockBit's services from June 2022 to February 2024; Treasury, citing DOJ, says over 2,500 victims worldwide. They count different things (Confirmed [18][19]).
- **Cronos keys and affiliates.** The NCA's announcement says 1,000 decryption keys and 194 affiliates identified; its lead release says over 1,000 keys and 28 affiliate servers taken down (Confirmed [16][93]).
- **The Integrity Technology Group botnet.** The joint advisory counts over 260,000 devices as of June 2024; Lumen counts over 60,000 active at its June 2023 peak and more than 200,000 over time (Confirmed [82]; Reported [120]).
- **Fuxnet's reach.** Claroty estimates about 500 gateways; the group claims 2,659 (Confirmed [34]; Reported [34]).
- **Sichuan Silence's count.** One reading of the Treasury release gives "tens of thousands" of firewalls, another about 81,000 (Confirmed [79]).

- **Operation Endgame.** One reading of the Europol page lists Trickbot and the dates 27 to 29 May from its metadata; another saw no date and no Trickbot (Confirmed [40]).
- **The telecom guidance date.** CISA's alert is dated 3 December; the guidance page is dated 4 December (Confirmed [76][77]).
- **ED 24-02's date.** CISA's alert is dated 11 April; the directive page opened did not show an issue date and is now marked closed (Confirmed [10][116]).
- **CVE-2024-1709's weakness.** The CNA gives CWE-288; NVD gives NVD-CWE-Other (Confirmed [133]).
- **CVE-2024-6387's weakness.** The CNA gives CWE-364; NVD gives CWE-362 (Confirmed [137]).
- **CVE-2024-3400's weakness.** NVD gives CWE-77; the CNA gives CWE-20 and CWE-77 (Confirmed [134]).
- **The CSRB report's location.** The report is dated 20 March 2024 but is served from a 2025 path on cisa.gov (Confirmed [117]).
- **The moved Microsoft address.** The old msrc.microsoft.com address of the 19 January post redirects to the blog index; this study cites the copy at microsoft.com [7].

Sources

All sources were opened on 11 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here. Addresses shown as code rather than as links refuse automated link checkers (the sec.gov filings, BeyondTrust's investigation page and the CourtListener docket); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	Cloudflare, Thanksgiving 2023 security incident, 1 Feb 2024	blog.cloudflare.com	2026-11-11	Confirmed
2	Volexity, Active exploitation of two zero-day vulnerabilities in Ivanti Connect Secure VPN, 10 Jan 2024	volexity.com	2026-11-11	Confirmed
3	CISA, Known Exploited Vulnerabilities catalog (JSON feed, catalog version 2026.11.10)	cisa.gov	2026-11-11	Confirmed
4	CISA, CISA issues Emergency Directive on Ivanti vulnerabilities, 19 Jan 2024	cisa.gov	2026-11-11	Confirmed
5	CISA and partners, AA24-060B, Threat actors exploit multiple vulnerabilities in Ivanti Connect Secure and Policy Secure gateways, 29 Feb 2024	cisa.gov	2026-11-11	Confirmed
6	Hewlett Packard Enterprise, Form 8-K, filed 24 Jan 2024	`https://www.sec.gov/Archives/edgar/data/1645590/000164559024000009/hpe-20240119.htm`	2026-11-11	Confirmed
7	Microsoft MSRC, Microsoft actions following attack by nation state actor Midnight Blizzard, 19 Jan 2024	microsoft.com	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
8	Microsoft MSRC, Update on Microsoft actions following attack by nation state actor Midnight Blizzard, 8 Mar 2024	microsoft.com	2026-11-11	Confirmed
9	Microsoft, Form 8-K/A, Item 1.05, filed 8 Mar 2024	https://www.sec.gov/Archives/edgar/data/789019/000119312524062997/d808756d8ka.htm	2026-11-11	Confirmed
10	CISA, CISA issues Emergency Directive 24-02, 11 Apr 2024	cisa.gov	2026-11-11	Confirmed
11	loanDepot, Form 8-K, filed 8 Jan 2024	https://www.sec.gov/Archives/edgar/data/1831631/000183163124000004/ldi-20240104.htm	2026-11-11	Confirmed
12	US Treasury, press release jy2072, sanctions on six IRGC-CEC officials, 2 Feb 2024	home.treasury.gov	2026-11-11	Confirmed
13	CISA, NSA, FBI and partners, AA24-038A, PRC state-sponsored actors compromise and maintain persistent access to US critical infrastructure, 7 Feb 2024 (read to character 100,000 of 132,303)	cisa.gov	2026-11-11	Confirmed
14	Microsoft Security, Staying ahead of threat actors in the age of AI, 14 Feb 2024	microsoft.com	2026-11-11	Confirmed
15	CISA, AA24-046A, a former employee's compromised account used to access a state government organization, 15 Feb 2024	cisa.gov	2026-11-11	Confirmed
16	UK National Crime Agency, The NCA announces the disruption of LockBit with Operation Cronos	nationalcrimeagency.gov.uk	2026-11-11	Confirmed
17	US Treasury, press release jy2114, sanctions on LockBit affiliates, 20 Feb 2024	home.treasury.gov	2026-11-11	Confirmed
18	UK National Crime Agency, LockBit leader unmasked and sanctioned, 7 May 2024	nationalcrimeagency.gov.uk	2026-11-11	Confirmed
19	US Treasury, press release jy2326, designation of Dmitry Khoroshev, 7 May 2024	home.treasury.gov	2026-11-11	Confirmed
20	ConnectWise, security bulletin, ScreenConnect 23.9.8, Feb 2024	connectwise.com	2026-11-11	Confirmed
21	UnitedHealth Group, Form 8-K, Item 1.05, filed 22 Feb 2024	https://www.sec.gov/Archives/edgar/data/731766/000073176624000045/unh-20240221.htm	2026-11-11	Confirmed
22	Change Healthcare, status page incident hqpjz25fn3n7 (posts from 21 Feb 2024)	status.changehealthcare.com	2026-11-11	Confirmed
23	UnitedHealth Group, UnitedHealth Group updates on Change Healthcare cyberattack, 22 Apr 2024	unitedhealthgroup.com	2026-11-11	Confirmed
24	CISA, AA24-057A, SVR cyber actors adapt tactics for initial cloud access, 26 Feb 2024	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
25	CISA, AA24-060A, #StopRansomware: Phobos, 29 Feb 2024	cisa.gov	2026-11-11	Confirmed
26	US Treasury, press release jy2155, sanctions on the Intellexa consortium, 5 Mar 2024	home.treasury.gov	2026-11-11	Confirmed
27	UK Government, UK holds China state-affiliated organisations and individuals responsible for malicious cyber activity, 25 Mar 2024	gov.uk	2026-11-11	Confirmed
28	US Treasury, press release jy2205, sanctions on Wuhan XRZ and two APT31-linked nationals, 25 Mar 2024	home.treasury.gov	2026-11-11	Confirmed
29	oss-security, Andres Freund, backdoor in upstream xz/liblzma leading to SSH server compromise, 29 Mar 2024	openwall.com	2026-11-11	Confirmed
30	CISA, Reported supply chain compromise affecting XZ Utils data compression library, CVE-2024-3094, 29 Mar 2024	cisa.gov	2026-11-11	Confirmed
31	CISA, Compromise of Sisense customer data, 11 Apr 2024	cisa.gov	2026-11-11	Confirmed
32	Volexity, Zero-day exploitation of unauthenticated remote code execution vulnerability in GlobalProtect (CVE-2024-3400), 12 Apr 2024	volexity.com	2026-11-11	Confirmed
33	Palo Alto Networks, security advisory CVE-2024-3400, 12 Apr 2024	security.paloaltonetworks.com	2026-11-11	Confirmed
34	Claroty Team82, Unpacking the Blackjack group's Fuxnet malware, Apr 2024	claroty.com	2026-11-11	Confirmed (Claroty's analysis); Reported (the group's claim)
35	Mandiant (Google Cloud), APT44: Unearthing Sandworm, 17 Apr 2024	cloud.google.com	2026-11-11	Confirmed
36	CISA, AA24-109A, #StopRansomware: Akira, 18 Apr 2024 (updated 13 Nov 2025)	cisa.gov	2026-11-11	Confirmed
37	US Treasury, press release jy2292, sanctions on IRGC-CEC fronts and individuals, 23 Apr 2024	home.treasury.gov	2026-11-11	Confirmed
38	Dropbox, A recent security incident involving Dropbox Sign, 1 May 2024	sign.dropbox.com	2026-11-11	Confirmed
39	CISA, AA24-131A, #StopRansomware: Black Basta, 10 May 2024 (revised 8 Nov 2024)	cisa.gov	2026-11-11	Confirmed
40	Europol, Largest ever operation against botnets hits dropper malware ecosystem, May 2024 (title and description only)	europol.europa.eu	2026-11-11	Confirmed
41	CISA, Snowflake recommends customers take steps to prevent unauthorized access, 3 Jun 2024	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
42	Mandiant (Google Cloud), UNC5537 targets Snowflake customer instances for data theft and extortion, 10 Jun 2024 (update 17 Jun)	cloud.google.com	2026-11-11	Confirmed
43	Live Nation Entertainment, Form 8-K, filed 31 May 2024	https://www.sec.gov/Archives/edgar/data/1335258/000133525824000081/lyv-20240520.htm	2026-11-11	Confirmed
44	AT&T, Form 8-K, filed 12 Jul 2024	https://www.sec.gov/Archives/edgar/data/732717/000073271724000046/t-20240506.htm	2026-11-11	Confirmed
45	Synnovis, cyberattack update site	synnoviscyberupdate.co.uk	2026-11-11	Confirmed
46	Sonic Automotive, Form 8-K, filed 21 Jun 2024 (CDK Global incident)	https://www.sec.gov/Archives/edgar/data/1043509/000104350924000059/sah-20240619.htm	2026-11-11	Confirmed
47	Cloudflare, Automatically replacing polyfill.io links with Cloudflare's mirror for a safer internet, 26 Jun 2024	blog.cloudflare.com	2026-11-11	Confirmed (Cloudflare's action); Reported (the injection reports it relays)
48	Qualys, regreSSHion: remote unauthenticated code execution in OpenSSH server (CVE-2024-6387), 1 Jul 2024	qualys.com	2026-11-11	Confirmed
49	ASD's ACSC, CISA, NSA, FBI and partners, AA24-190A, PRC MSS tradecraft in action (APT40), 8 Jul 2024	cisa.gov	2026-11-11	Confirmed
50	CrowdStrike, Technical details: Falcon update for Windows hosts, 20 Jul 2024	crowdstrike.com	2026-11-11	Confirmed
51	CISA, Widespread IT outage due to CrowdStrike update, 19 Jul 2024	cisa.gov	2026-11-11	Confirmed
52	Microsoft, Helping our customers through the CrowdStrike outage, 20 Jul 2024	blogs.microsoft.com	2026-11-11	Confirmed
53	US Treasury, press release jy2473, sanctions on Cyber Army of Russia Reborn members, 19 Jul 2024	home.treasury.gov	2026-11-11	Confirmed
54	Unit 42 (Palo Alto Networks), FrostyGoop malware analysis, Jul 2024	unit42.paloaltonetworks.com	2026-11-11	Confirmed
55	FBI and partners, AA24-207A, North Korea cyber group conducts global espionage campaign (Andariel), 25 Jul 2024	cisa.gov	2026-11-11	Confirmed
56	Mandiant (Google Cloud), APT45: North Korea's digital military machine, 25 Jul 2024	cloud.google.com	2026-11-11	Confirmed
57	Halliburton, Form 8-K, filed 23 Aug 2024	https://www.sec.gov/Archives/edgar/data/45012/000004501224000049/hal-20240821.htm	2026-11-11	Confirmed
58	Halliburton, Form 8-K, filed Sep 2024 (report date 30 Aug 2024)	https://www.sec.gov/Archives/edgar/data/45012/000004501224000052/hal-20240830.htm	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
59	CISA, AA24-241A, Iran-based cyber actors enabling ransomware attacks on US organizations, 28 Aug 2024	cisa.gov	2026-11-11	Confirmed
60	CISA, AA24-242A, #StopRansomware: RansomHub, 29 Aug 2024	cisa.gov	2026-11-11	Confirmed
61	FBI, CISA, NSA and partners, AA24-249A, Russian military cyber actors target US and global critical infrastructure, 5 Sep 2024	cisa.gov	2026-11-11	Confirmed
62	UK NCSC, NCSC and partners issue advice to counter China-linked campaign targeting thousands of devices, 18 Sep 2024	ncsc.gov.uk	2026-11-11	Confirmed
63	Microsoft Security, Storm-0501: ransomware attacks expanding to hybrid cloud environments, 26 Sep 2024	microsoft.com	2026-11-11	Confirmed
64	US Treasury, press release jy2621, designations for Iranian election interference, 27 Sep 2024	home.treasury.gov	2026-11-11	Confirmed
65	US Treasury, press release jy2623, designations of Evil Corp members, 1 Oct 2024	home.treasury.gov	2026-11-11	Confirmed
66	Microsoft On the Issues, Protecting democratic institutions from cyber threats, 3 Oct 2024	blogs.microsoft.com	2026-11-11	Confirmed
67	American Water Works, Form 8-K, filed 7 Oct 2024	`https://www.sec.gov/Archives/edgar/data/1410636/000119312524233300/d869346d8k.htm`	2026-11-11	Confirmed
68	CISA, AA24-290A, Iranian cyber actors' brute force and credential access activity, 16 Oct 2024	cisa.gov	2026-11-11	Confirmed
69	Mandiant (Google Cloud), Investigating FortiManager zero-day exploitation (CVE-2024-47575), 23 Oct 2024	cloud.google.com	2026-11-11	Confirmed
70	Fortinet PSIRT, FG-IR-24-423, missing authentication in fgfmd, Oct 2024	fortiguard.com	2026-11-11	Confirmed
71	CISA, Fortinet updates guidance and indicators of compromise following FortiManager vulnerability, 30 Oct 2024	cisa.gov	2026-11-11	Confirmed
72	Dutch National Police and partners, Operation Magnus, 28 Oct 2024	operation-magnus.com	2026-11-11	Confirmed
73	CISA, Foreign threat actor conducting large-scale spearphishing campaign with RDP attachments, 31 Oct 2024	cisa.gov	2026-11-11	Confirmed
74	CISA and partners, AA24-317A, 2023 Top Routinely Exploited Vulnerabilities, 12 Nov 2024	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
75	FBI and CISA, Joint statement on People's Republic of China targeting of commercial telecommunications infrastructure, 13 Nov 2024	cisa.gov	2026-11-11	Confirmed
76	CISA, CISA and partners release joint guidance on PRC-affiliated threat actor compromising networks of global telecommunications providers, 3 Dec 2024	cisa.gov	2026-11-11	Confirmed
77	CISA, NSA, FBI, ASD's ACSC, CCCS and NCSC-NZ, Enhanced Visibility and Hardening Guidance for Communications Infrastructure, 4 Dec 2024	cisa.gov	2026-11-11	Confirmed
78	Microsoft Security, Frequent freeloader part I: Secret Blizzard compromising Storm-0156 infrastructure for espionage, 4 Dec 2024	microsoft.com	2026-11-11	Confirmed
79	US Treasury, press release jy2742, sanctions on Sichuan Silence and Guan Tianfeng, 10 Dec 2024	home.treasury.gov	2026-11-11	Confirmed
80	Krispy Kreme, Form 8-K, filed 11 Dec 2024	`https://www.sec.gov/Archives/edgar/data/1857154/000185715424000123/dnut-20241211.htm`	2026-11-11	Confirmed
81	BeyondTrust, Remote Support SaaS service security investigation	`https://www.beyondtrust.com/remote-support-saas-service-security-investigation`	2026-11-11	Confirmed
82	FBI, CNMF and NSA, JCSA-20240918-001, People's Republic of China-linked actors compromise routers and IoT devices for botnet operations, 18 Sep 2024	ic3.gov	2026-11-11	Confirmed
83	MITRE ATT&CK, group G1045 Salt Typhoon	attack.mitre.org	2026-11-11	Confirmed (the record); Inferred (the 2024 binding)
84	Mandiant (Google Cloud), suspected APT targets Ivanti Connect Secure zero-days (UNC5221), 11 Jan 2024	cloud.google.com	2026-11-11	Confirmed
85	Sygnia, China-nexus threat group Velvet Ant (F5 load balancer persistence), 3 Jun 2024	sygnia.co	2026-11-11	Confirmed
86	Mandiant (Google Cloud), Uncovering UNC3886 espionage operations, 18 Jun 2024	cloud.google.com	2026-11-11	Confirmed
87	NCSC-UK, NSA, CISA, CNMF, FBI and partners, SVR cyber actors adapt tactics for initial cloud access (PDF), Feb 2024	ic3.gov	2026-11-11	Confirmed
88	Volexity, The nearest neighbor attack: how a Russian APT weaponized nearby Wi-Fi networks for covert access, 22 Nov 2024	volexity.com	2026-11-11	Confirmed
89	Google Threat Analysis Group, Iranian-backed group steps up phishing campaigns against Israel, US, 14 Aug 2024	blog.google	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
90	Microsoft Security, Moonstone Sleet emerges as new North Korean threat actor with new bag of tricks, 28 May 2024	microsoft.com	2026-11-11	Confirmed
91	Cisco Talos, ArcaneDoor: new espionage-focused campaign found targeting perimeter network devices, Apr 2024	blog.talosintelligence.com	2026-11-11	Confirmed
92	TeamStarWolf library, ATT&CK group and software data (`data/attack/groups.jsonl`, `software.jsonl`, `ics/software.jsonl`) and generated pages (`mitre/groups/`, `mitre/software/`)	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
93	UK National Crime Agency, NCA leads international investigation targeting world's most harmful ransomware group, 20 Feb 2024	nationalcrimeagency.gov.uk	2026-11-11	Confirmed
94	Europol, Law enforcement disrupt world's biggest ransomware operation, 20 Feb 2024 (title and description only)	europol.europa.eu	2026-11-11	Confirmed
95	US Treasury, press release jy2375, sanctions over the 911 S5 botnet, 28 May 2024	home.treasury.gov	2026-11-11	Confirmed
96	Europol, LockBit power cut: four new arrests and financial sanctions against affiliates, 1 Oct 2024 (title, description and date only)	europol.europa.eu	2026-11-11	Confirmed
97	CISA, AA23-353A, #StopRansomware: ALPHV Blackcat (19 Dec 2023, updated 27 Feb 2024)	cisa.gov	2026-11-11	Confirmed
98	FBI Internet Crime Complaint Center, 2024 Internet Crime Report	ic3.gov	2026-11-11	Confirmed
99	Chainalysis, Ransomware payments and victim extortion, 2025 crypto crime report chapter	chainalysis.com	2026-11-11	Reported
100	Coveware, Q4 2024 quarterly report, 31 Jan 2025	coveware.com	2026-11-11	Reported
101	Ivanti, Security update for Ivanti Connect Secure and Ivanti Policy Secure gateways	ivanti.com	2026-11-11	Confirmed
102	CISA, ED 24-01: Mitigate Ivanti Connect Secure and Ivanti Policy Secure vulnerabilities	cisa.gov	2026-11-11	Confirmed
103	Fortinet PSIRT, FG-IR-24-015, FortiOS SSL VPN out-of-bounds write, 8 Feb 2024	fortiguard.com	2026-11-11	Confirmed
104	JetBrains, Additional critical security issues affecting TeamCity On-Premises (CVE-2024-27198 and CVE-2024-27199), 4 Mar 2024	blog.jetbrains.com	2026-11-11	Confirmed
105	NVD, CVE-2023-48788 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
106	NVD, CVE-2024-4040 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed
107	Check Point, sk182336, Security Gateway information disclosure hotfix	support.checkpoint.com	2026-11-11	Confirmed
108	NVD, CVE-2024-4577 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed
109	Microsoft Security, Ransomware operators exploit ESXi hypervisor vulnerability for mass encryption, 29 Jul 2024	microsoft.com	2026-11-11	Confirmed
110	Veeam, KB4649, Veeam Backup & Replication vulnerabilities (Sep 2024)	veeam.com	2026-11-11	Confirmed
111	Palo Alto Networks, security advisory CVE-2024-0012 (PAN-SA-2024-0015)	security.paloaltonetworks.com	2026-11-11	Confirmed
112	NVD, CVE-2024-55956 (API record; with CVE-2024-50623 in the KEV catalog)	services.nvd.nist.gov	2026-11-11	Confirmed
113	NVD, CVE-2024-3094 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed
114	Microsoft, Form 8-K exhibit 99.1, filed 19 Jan 2024	`https://www.sec.gov/Archives/edgar/data/789019/000119312524011295/d708866dex991.htm`	2026-11-11	Confirmed
115	Microsoft, Form 8-K/A exhibit 99.1, filed 8 Mar 2024	`https://www.sec.gov/Archives/edgar/data/789019/000119312524062997/d808756dex991.htm`	2026-11-11	Confirmed
116	CISA, ED 24-02: Mitigating the significant risk from nation-state compromise of Microsoft corporate email system (closed)	cisa.gov	2026-11-11	Confirmed
117	Cyber Safety Review Board, Review of the Summer 2023 Microsoft Exchange Online intrusion, 20 Mar 2024	cisa.gov	2026-11-11	Confirmed
118	CISA and partners, Defending OT operations against ongoing pro-Russia hacktivist activity, 1 May 2024	cisa.gov	2026-11-11	Confirmed
119	CISA, Threat actors continue to exploit OT/ICS through unsophisticated means, 25 Sep 2024	cisa.gov	2026-11-11	Confirmed
120	Lumen Black Lotus Labs, Derailing the Raptor Train, Sep 2024	blog.lumen.com	2026-11-11	Reported
121	Federal Register, Final Determination: Case No. ICTS-2021-002, Kaspersky Lab, Inc., 24 Jun 2024 (89 FR 52434)	federalregister.gov	2026-11-11	Confirmed
122	CourtListener, docket of SEC v. SolarWinds Corp., 1:23-cv-09518 (S.D.N.Y.), Opinion and Order of 18 Jul 2024 (entry 125)	`https://www.courtlistener.com/docket/67927585/securities-and-exchange-commission-v-solarwinds-corp/`	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
123	Federal Register, Executive Order 14117, Preventing access to Americans' bulk sensitive personal data, 1 Mar 2024 (89 FR 15421)	federalregister.gov	2026-11-11	Confirmed
124	Federal Register, Cyber Incident Reporting for Critical Infrastructure Act (CIRCIA) reporting requirements, proposed rule, 4 Apr 2024 (89 FR 23644)	federalregister.gov	2026-11-11	Confirmed
125	The White House (archive), National Security Memorandum on Critical Infrastructure Security and Resilience (NSM-22), 30 Apr 2024	bidenwhitehouse.archives.gov	2026-11-11	Confirmed
126	NIST, NIST releases version 2.0 of landmark Cybersecurity Framework, 26 Feb 2024	nist.gov	2026-11-11	Confirmed
127	NIST, NIST releases first 3 finalized post-quantum encryption standards, 13 Aug 2024	nist.gov	2026-11-11	Confirmed
128	UK Government, New laws to protect consumers from cyber criminals come into force in the UK, 29 Apr 2024	gov.uk	2026-11-11	Confirmed
129	European Commission, NIS2 Directive policy page	digital-strategy.ec.europa.eu	2026-11-11	Confirmed
130	Australian Federal Register of Legislation, Cyber Security Act 2024 (No. 98, 2024), as made	legislation.gov.au	2026-11-11	Confirmed
131	UNODC, United Nations Convention against Cybercrime	unodc.org	2026-11-11	Confirmed
132	Microsoft Security, Midnight Blizzard: guidance for responders on nation-state attack, 25 Jan 2024	microsoft.com	2026-11-11	Confirmed
133	NVD, CVE-2024-1709 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed
134	NVD, CVE-2024-3400 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed
135	NVD, CVE-2024-47575 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed
136	NVD, CVE-2024-24919 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed
137	NVD, CVE-2024-6387 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed
138	CrowdStrike, Falcon content update preliminary post incident review, Jul 2024	crowdstrike.com	2026-11-11	Confirmed
139	CISA, CISA announces Secure by Design commitments from leading technology providers, 8 May 2024	cisa.gov	2026-11-11	Confirmed
140	TeamStarWolf library, `data/attack/superseded_by.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
141	TeamStarWolf library, `data/attack/technique_to_d3fend.jsonl` and `data/attack/d3fend_countermeasures.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
142	TeamStarWolf library, `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl` and the CAPEC pages under `mitre/capec/`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
143	TeamStarWolf library, `data/attack/campaigns.jsonl` and `campaign_profiles.jsonl`, and the pages under `mitre/campaigns/`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
144	NVD, CVE-2023-46805 and CVE-2024-21887 (API record for CVE-2024-21887 shown)	services.nvd.nist.gov	2026-11-11	Confirmed
145	NVD, CVE-2024-21893 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed
146	TeamStarWolf library, `data/attack/technique_profiles.jsonl` and the pages under `mitre/techniques/`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- Ransomware Defense Reference, Edge Device Security Reference, Cloud Attack Reference, Identity Security Reference, ICS/OT Security Reference, ICS ATT&CK Atlas, Supply Chain Security, Vulnerability Prioritization Reference, Incident Response Reference, AI Security Reference
- Home studies: The Change Healthcare attack of 2024; SSHole: the OpenSSH authentication bypass; The Ransomware Ecosystem; The XZ Utils backdoor; ICS attacks and advisories, 2024 to 2026; China-attributed actors; Russia-attributed actors; Iran-attributed actors; North Korea-attributed actors; Sandworm; Zero-day market events
- Related studies: Log4Shell; The Cl0p MOVEit breach and the file-transfer extortion playbook; SolarWinds and SUNBURST; APT41: the public record; npm supply-chain attacks; Hugging Face supply chain;

Stuxnet; Healthcare threat actor watchlist; AI threats; Exchange Marauder, 2021

- Series: 2016, 2017, 2018, 2019, 2020, 2021, 2022
- Groups: G1017 Volt Typhoon, G1045 Salt Typhoon, G0128 ZIRCONIUM, G0065 Leviathan, G1047 Velvet Ant, G1048 UNC3886, G0016 APT29, G0034 Sandworm Team, G1003 Ember Bear, G0007 APT28, G1033 Star Blizzard, G0010 Turla, G0117 Fox Kitten, G1044 APT42, G0138 Andariel, G1036 Moonstone Sleet, G0119 Indrik Spider, G1015 Scattered Spider, G1053 Storm-0501, G1024 Akira
- Campaigns: C0029 Cutting Edge, C0035 KV Botnet Activity, C0039 Versa Director Zero Day Exploitation, C0041 FrostyGoop Incident, C0046 ArcaneDoor, C0048 Operation MidnightEclipse, C0051 APT28 Nearest Neighbor Campaign
- Software: S1068 BlackCat, S1202 LockBit 3.0, S1199 LockBit 2.0, S1070 Black Basta, S1129 Akira, S1212 RansomHub, S0650 QakBot, S0483 IcedID, S9001 SystemBC, S1145 Pikabot, S0226 Smoke Loader, S1039 Bumblebee, S0266 TrickBot, S1240 RedLine Stealer, S1213 Lumma Stealer, S9050 Vidar, S1164 UPSTYLE, S1186 Line Dancer, S1188 Line Runner, S0689 WhisperGate
- Techniques: T1190 Exploit Public-Facing Application, T1505.003 Web Shell, T1078.004 Cloud Accounts, T1110.003 Password Spraying, T1528 Steal Application Access Token, T1098.003 Additional Cloud Roles, T1114.002 Remote Email Collection, T1584.005 Botnet, T1566.004 Spearphishing Voice, T1195.002 Compromise Software Supply Chain, T1486 Data Encrypted for Impact, T1685 Disable or Modify Tools
- CAPEC: CAPEC-565, CAPEC-560, CAPEC-555, CAPEC-115, CAPEC-248, CAPEC-88, CAPEC-664, CAPEC-442, CAPEC-26, CAPEC-586
- Navigator layers, including this study's layer, chronicle-2024.json